INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC 103 - Week 1 Lab Assignment

Risk Assessment and Management Techniques

Practical Vulnerability Assessment for GRC Professionals

Name	Adeshola Oluwole
Registration Number	C1126CGRCE17211
Course	**GRC 103 Risk Assessment and Management Techniques**
Module	Module 1 – **Risk Identification Techniques**
Opens	18 October 2026, 5:41 PM WAT
Due	25 October 2026, 11:59 PM WAT

1. Introduction

A GRC analyst role transcends merely identifying technical flaws. It requires understanding their impact on organizational risk posture and compliance status. This lab will entail conducting a technical assessment on a test system as an Internal Auditor. The primary deliverable will be a management-focused summary that translates technical findings into business risk and compliance terms.

Scenario

An Internal Auditor has been tasked with performing a vulnerability assessment on a newly discovered test server (Metasploitable 2) within the company's development environment with the objective of identifying, classifying, and reporting the vulnerabilities from a risk and compliance perspective, thereby providing actionable insights for remediation.

2. Objectives

- Discover live hosts and identify open ports/services.
- Enumerate software versions and identify known vulnerabilities.
- Analyze findings and map them to common compliance frameworks (e.g., NIST, CIS, PCI DSS).
- Assess the risk level of each finding.
- Document your results in a structured, professional format, including visual reports.

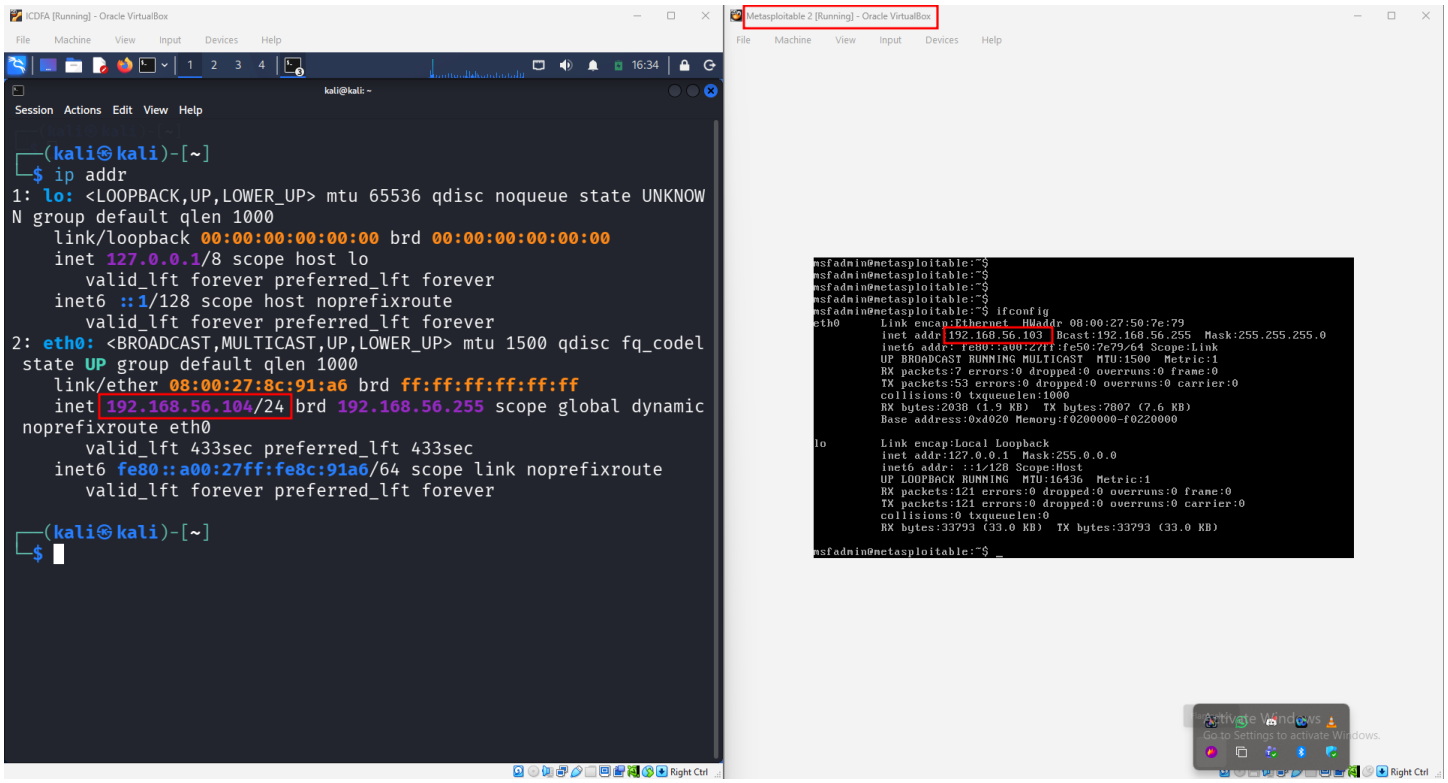
3. Deliverables

The following deliverables will be submitted:

1. Nmap output files (initial_scan.nmap, initial_scan.xml).
2. Screenshot of the Nmap HTML report (initial_scan_report.html).
3. Nikto and Nuclei scan outputs.
4. Completed Risk Assessment Table.
5. Executive Summary.

4. Lab Setup

- **Attacker Machine:** Kali Linux - IP: 192.168.56.104 (VB) / 192.168.60.129 (VMW)
- **Target Machine:** Metasploitable (Victim) - IP: 192.168.56.103 (VB) / 192.168.60.130 (VMW)
- **Tools:** nmap, nikto, nuclei, xsltproc

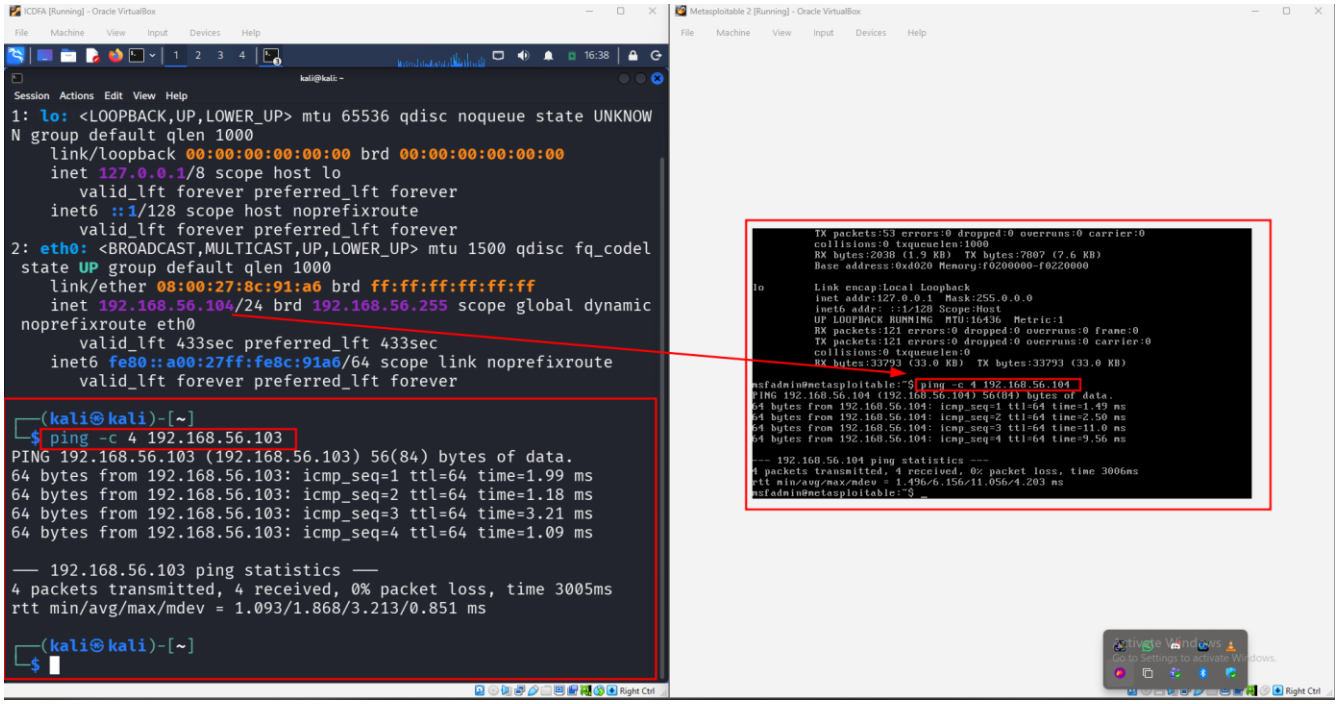


5. Step-by-Step Instructions

Phase 1: Discovery and Enumeration

Step 1: Network Discovery

- **Task:** Confirm the target is alive and identify its IP address.
- **Command:** ping -c 4 <TARGET_IP>



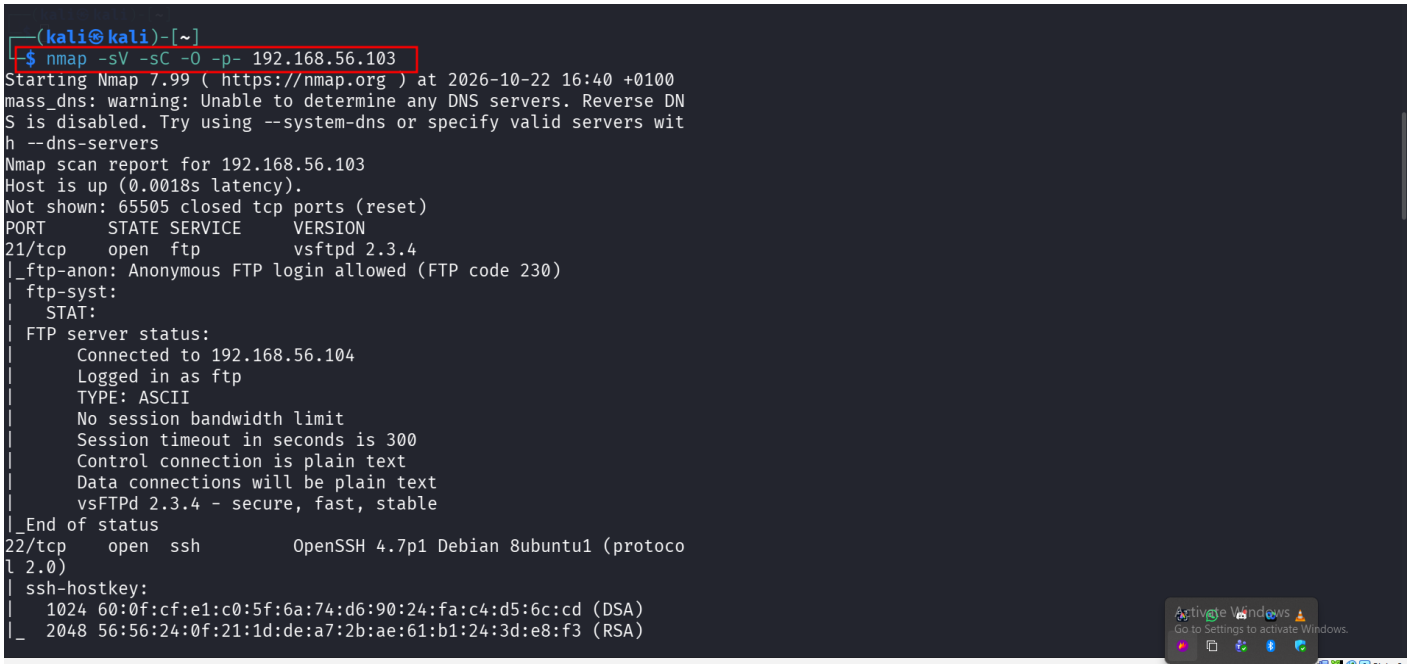
- ❖ **GRC Context:** This initial step is foundational for asset inventory management, a requirement in frameworks like **NIST CSF (ID.AM-1)** and **CIS Control 1**. One cannot protect or assess what you do not know exists.

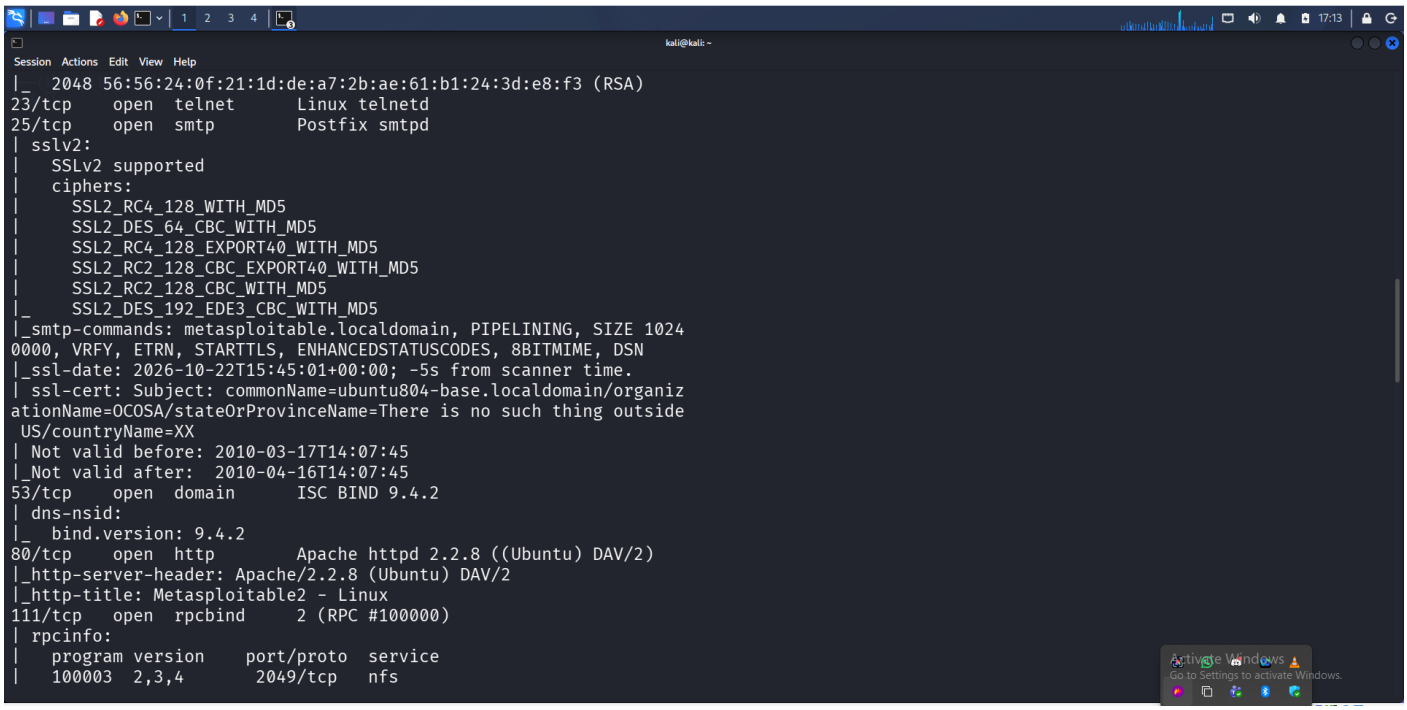
Step 2: Port and Service Enumeration with Nmap

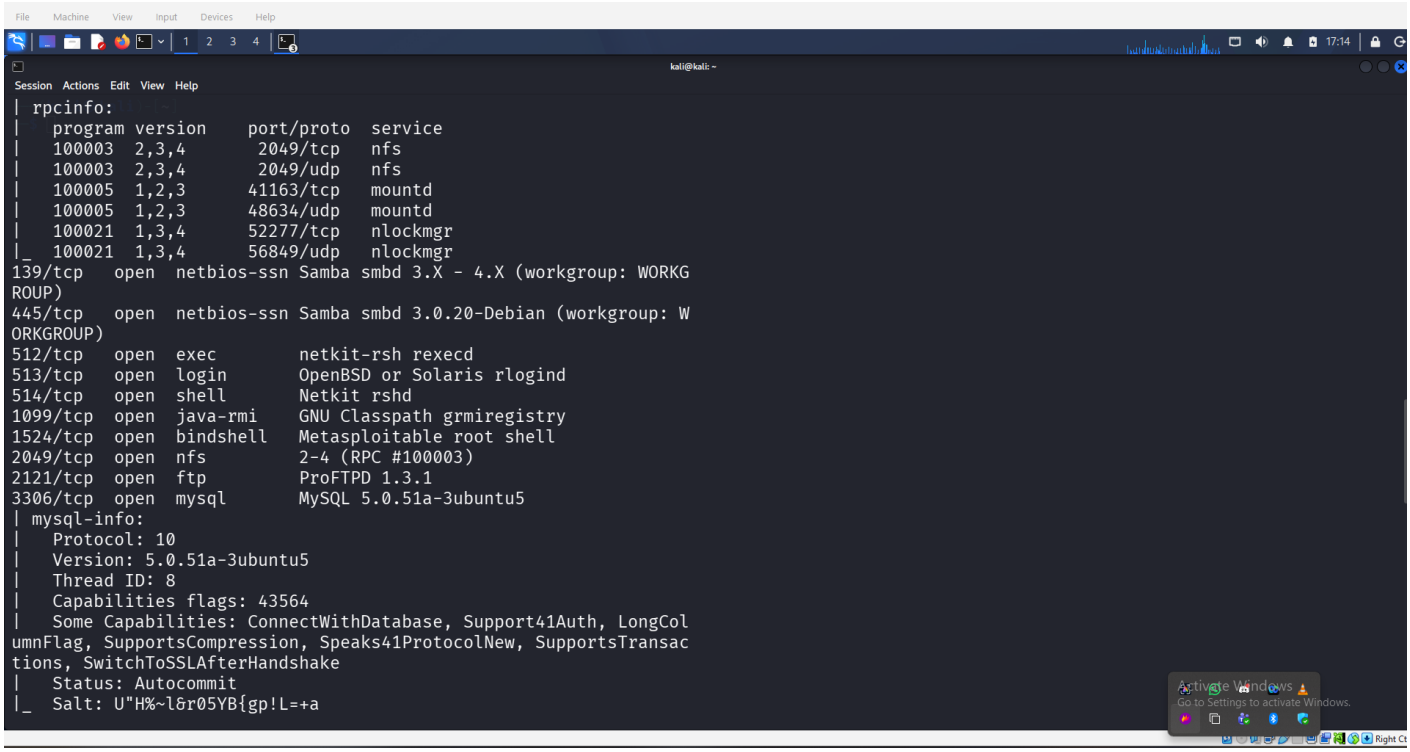
- **Task:** Perform a comprehensive scan to identify all open ports, services, and versions.
- **Command:**

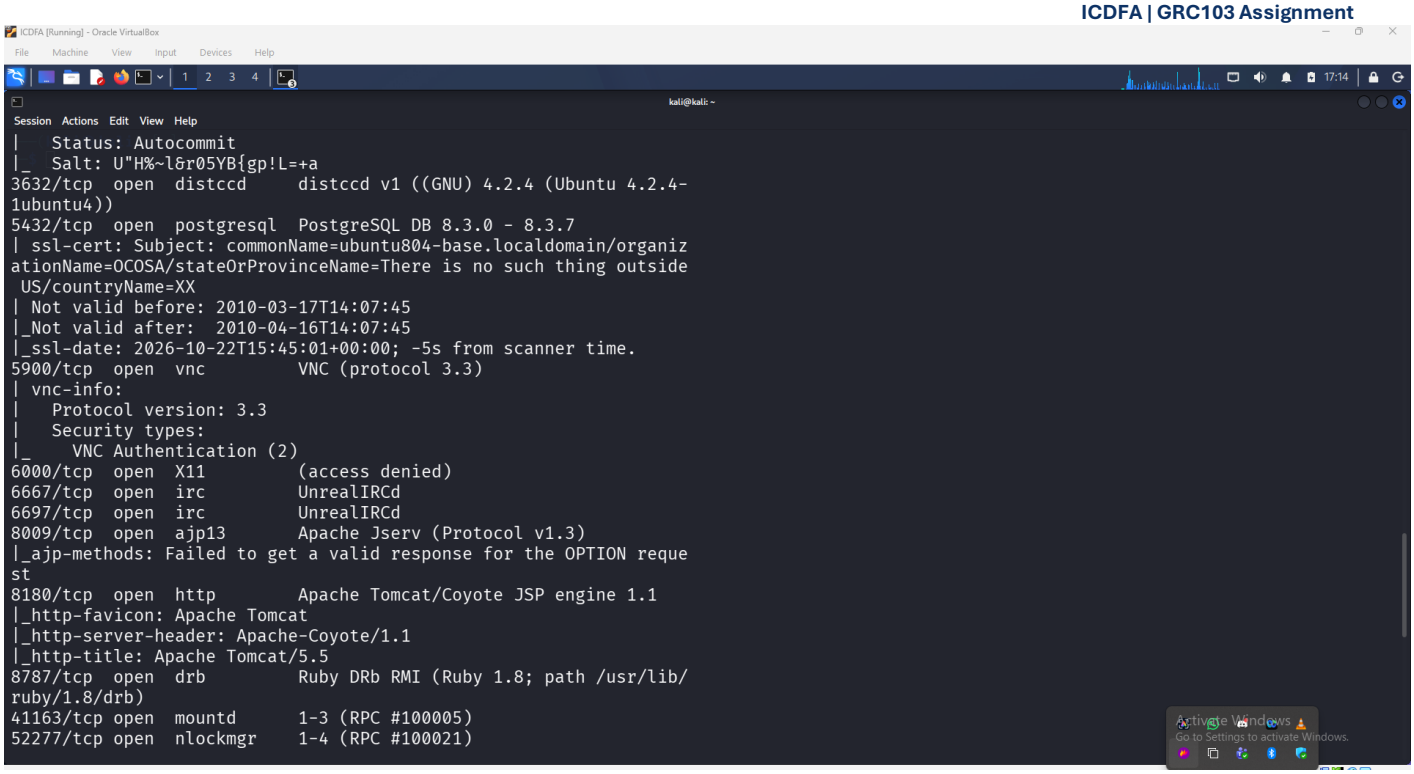
nmap -sV -sC -O -p- <TARGET_IP>

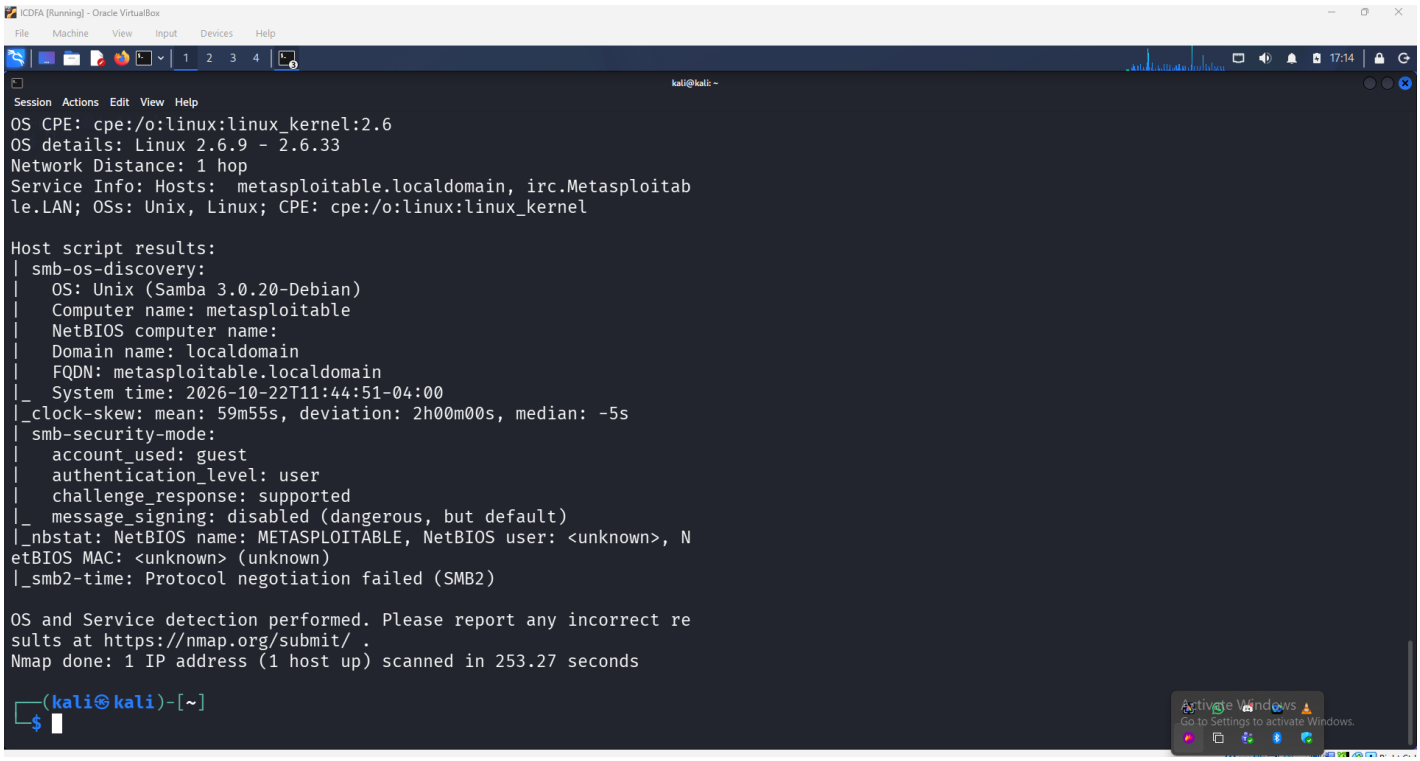
- ➢ -sV: Probe open ports to determine service/version info.
- ➢ -sC: Run default Nmap scripts (safe for discovery).
- ➢ -O: Enable OS detection.
- ➢ -p-: Scan all 65,535 ports.




kali@kali: ~
Session Actions Edit View Help
|_ 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open telnet   Linux telnetd
25/tcp   open smtp   Postfix smtpd
| sslv2:
| SSLv2 supported
| ciphers:
| SSL2_RC4_128_WITH_MD5
| SSL2_DES_64_CBC_WITH_MD5
| SSL2_RC4_128_EXPORT40_WITH_MD5
| SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
| SSL2_RC2_128_CBC_WITH_MD5
|_   SSL2_DES_192_EDE3_CBC_WITH_MD5
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 1024
0000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ssl-date: 2026-10-22T15:45:01+00:00; -5s from scanner time.
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organiz
ationName=OCOSA/stateOrProvinceName=There is no such thing outside
 US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
53/tcp   open domain   ISC BIND 9.4.2
| dns-nsid:
|_ bind.version: 9.4.2
80/tcp   open http   Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp   open rpcbind   2 (RPC #100000)
| rpcinfo:
| program version   port/proto service
| 100003 2,3,4   2049/tcp   nfs


kali@kali: ~
Session Actions Edit View Help
| rpcinfo:
| program version   port/proto service
| 100003 2,3,4   2049/tcp   nfs
| 100003 2,3,4   2049/udp   nfs
| 100005 1,2,3   41163/tcp   mountd
| 100005 1,2,3   48634/udp   mountd
| 100021 1,3,4   52277/tcp   nlockmgr
|_ 100021 1,3,4   56849/udp   nlockmgr
139/tcp   open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKG
ROUP)
445/tcp   open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: W
ORKGROUP)
512/tcp   open exec   netkit-rsh rexecd
513/tcp   open login   OpenBSD or Solaris rlogind
514/tcp   open shell   Netkit rshd
1099/tcp open java-rmi   GNU Classpath grmiregistry
1524/tcp open bindshell   Metasploitable root shell
2049/tcp open nfs   2-4 (RPC #100003)
2121/tcp open ftp   ProFTPD 1.3.1
3306/tcp open mysql   MySQL 5.0.51a-3ubuntu5
| mysql-info:
| Protocol: 10
| Version: 5.0.51a-3ubuntu5
| Thread ID: 8
| Capabilities flags: 43564
| Some Capabilities: ConnectWithDatabase, Support41Auth, LongCol
umnFlag, SupportsCompression, Speaks41ProtocolNew, SupportsTransac
tions, SwitchToSSLAfterHandshake
| Status: Autocommit
|_ Salt: U"H%~l&r05YB{gp!L=+a



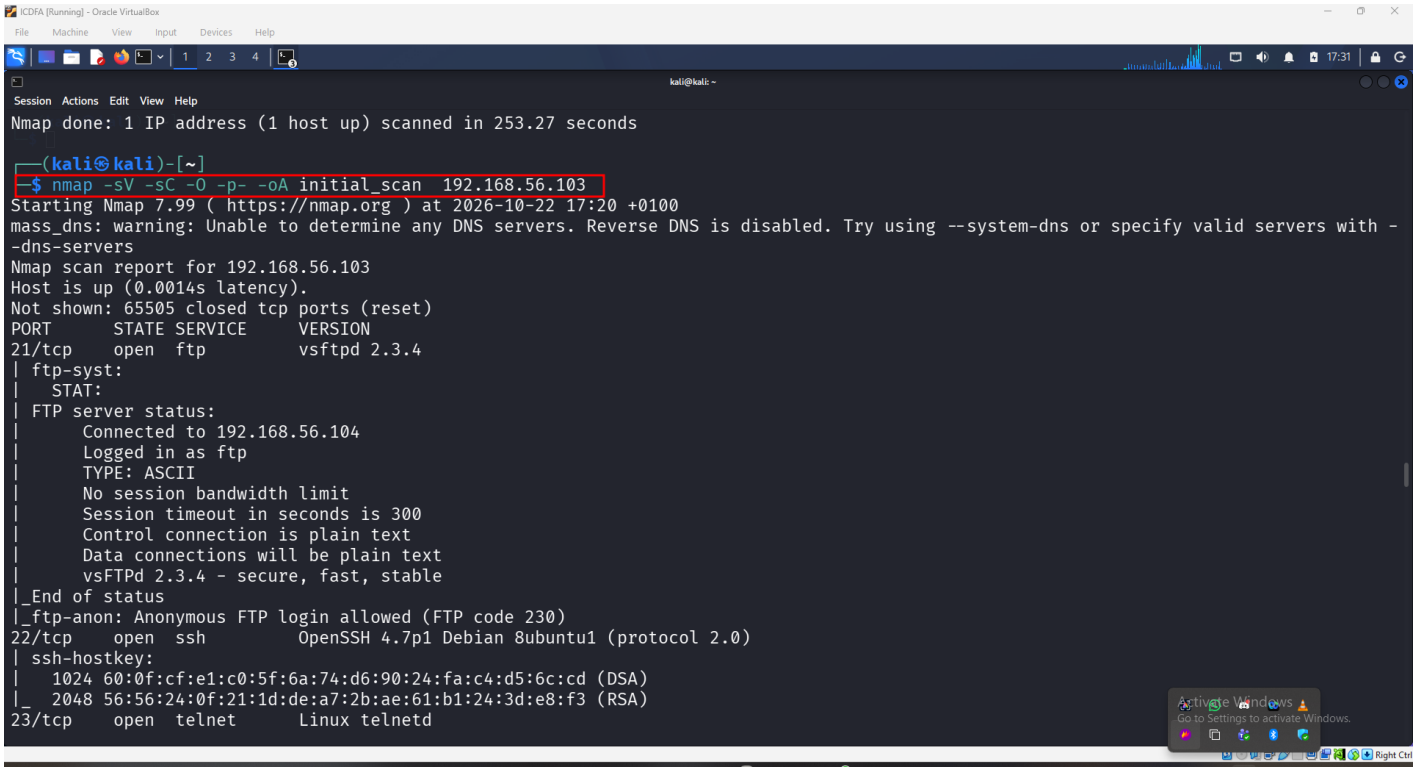


- **Action:**

1. **Save output in multiple formats** for comprehensive documentation and analysis:

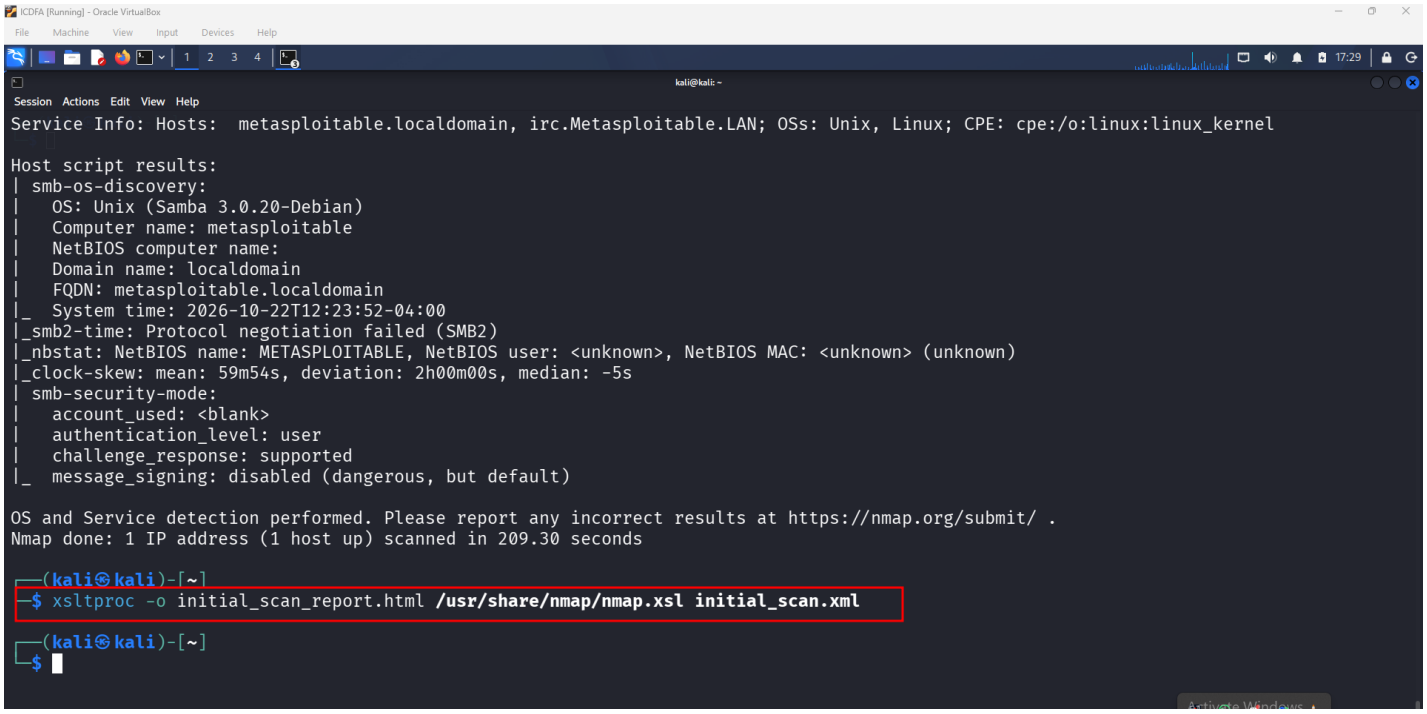
nmap -sV -sC -O -p- -oA initial_scan <TARGET_IP>

This generates three files: initial_scan.nmap, initial_scan.gnmap, and initial_scan.xml.

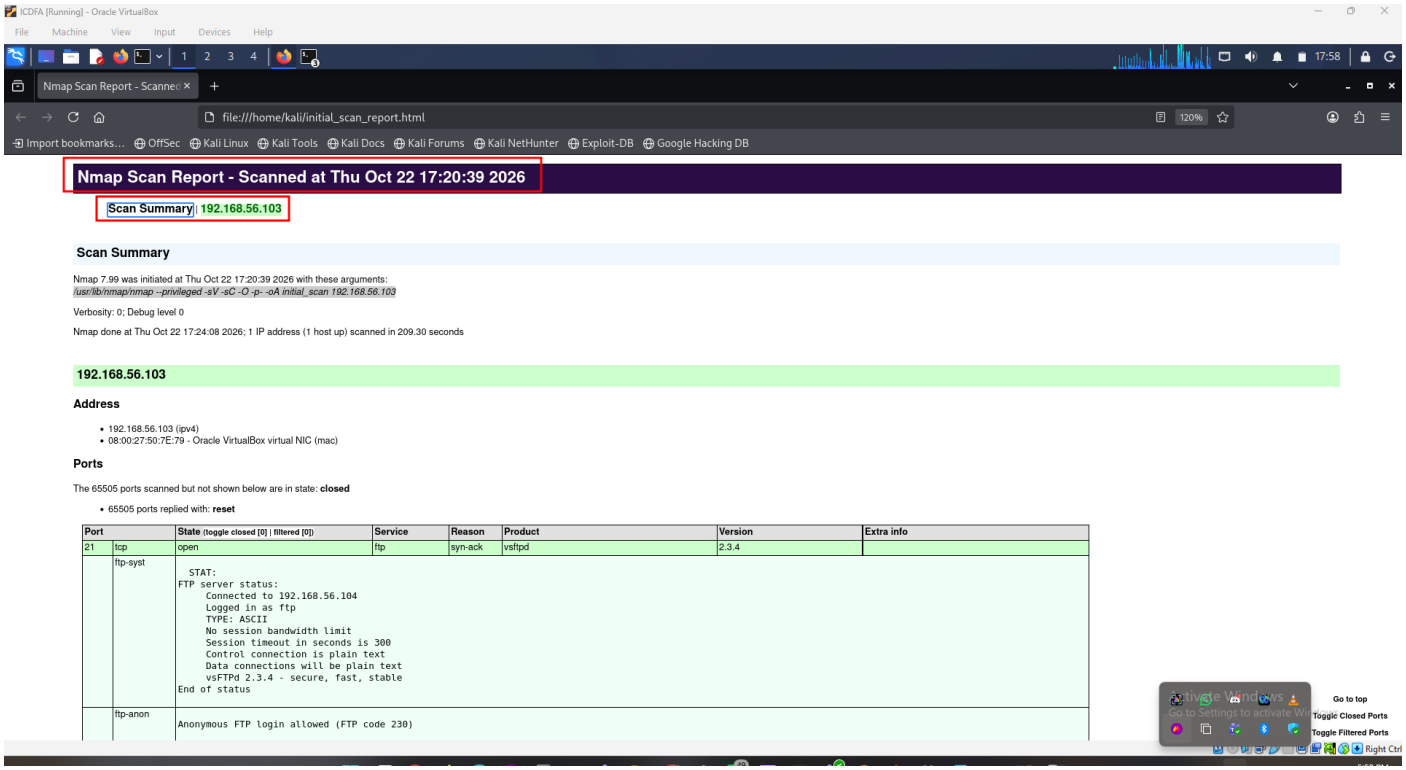


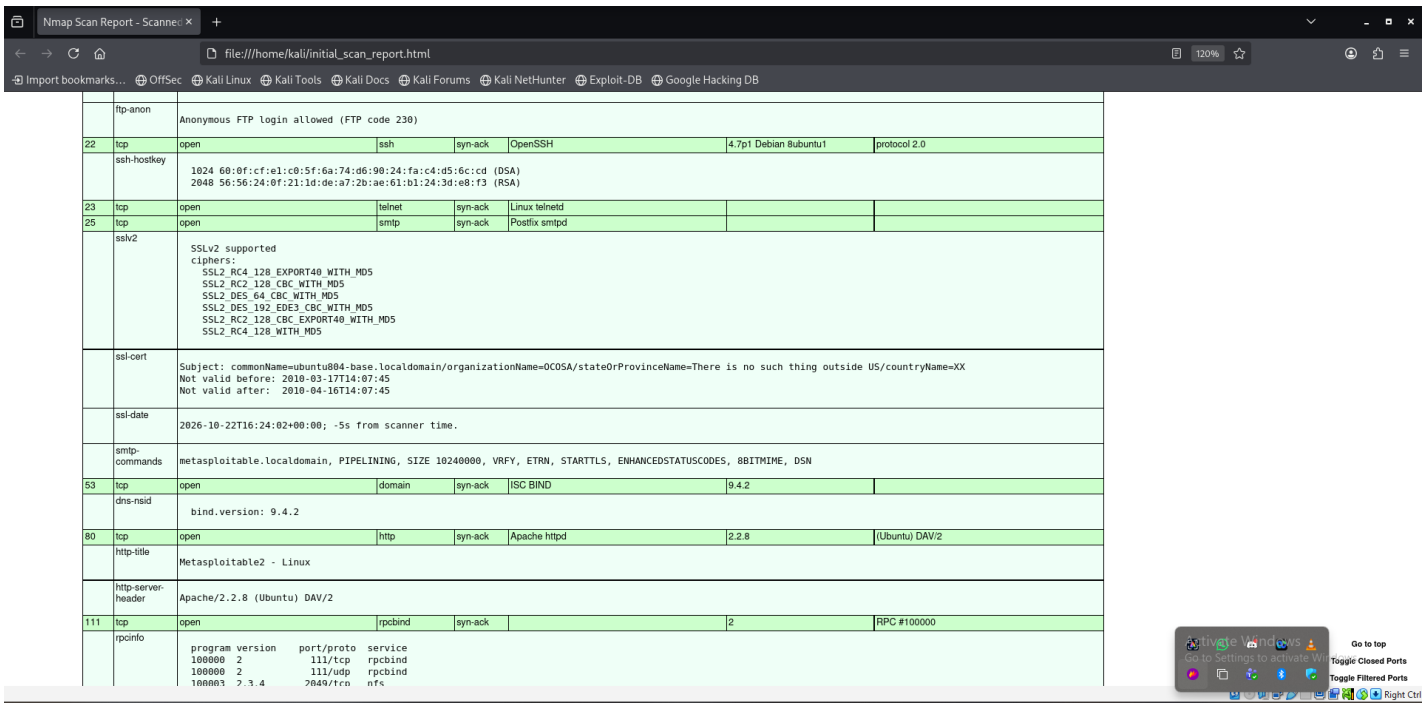
2. **Generate an HTML report** for enhanced visualization and reporting:

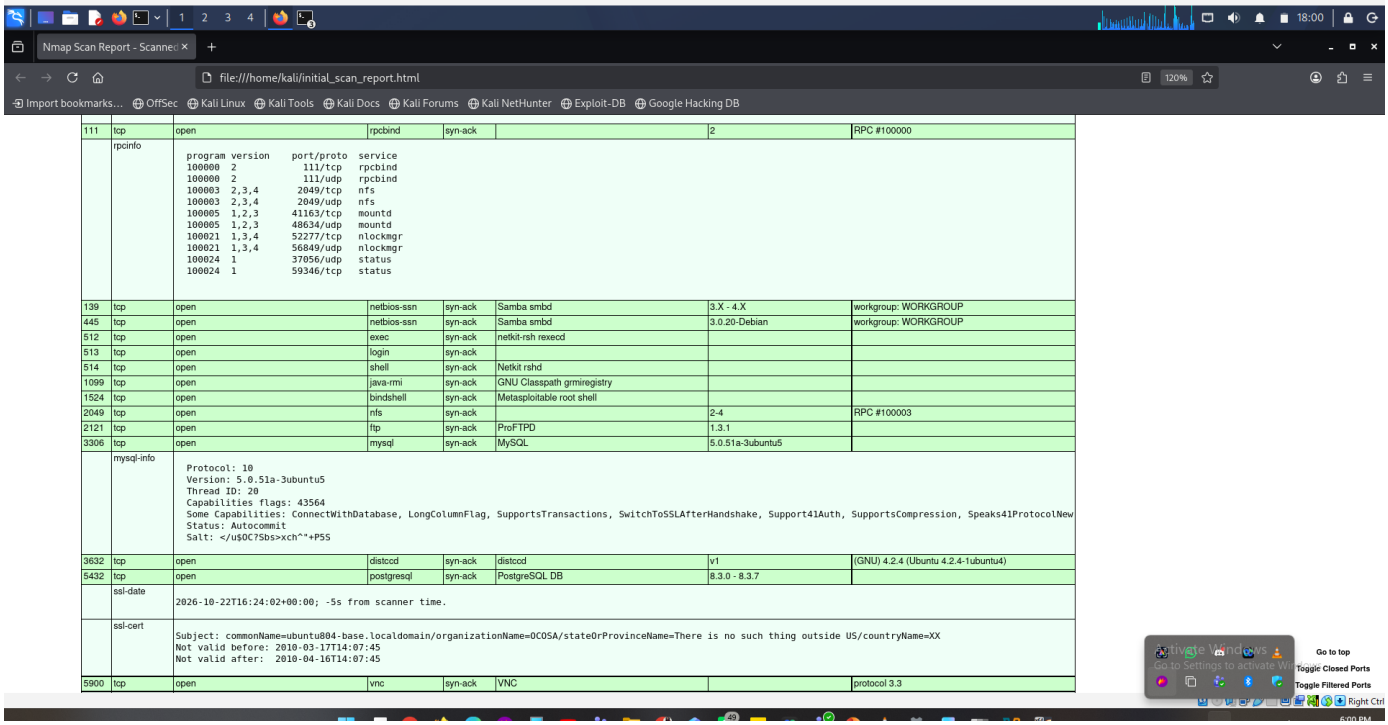
xsltproc -o initial_scan_report.html /usr/share/nmap/nmap.xsl initial_scan.xml



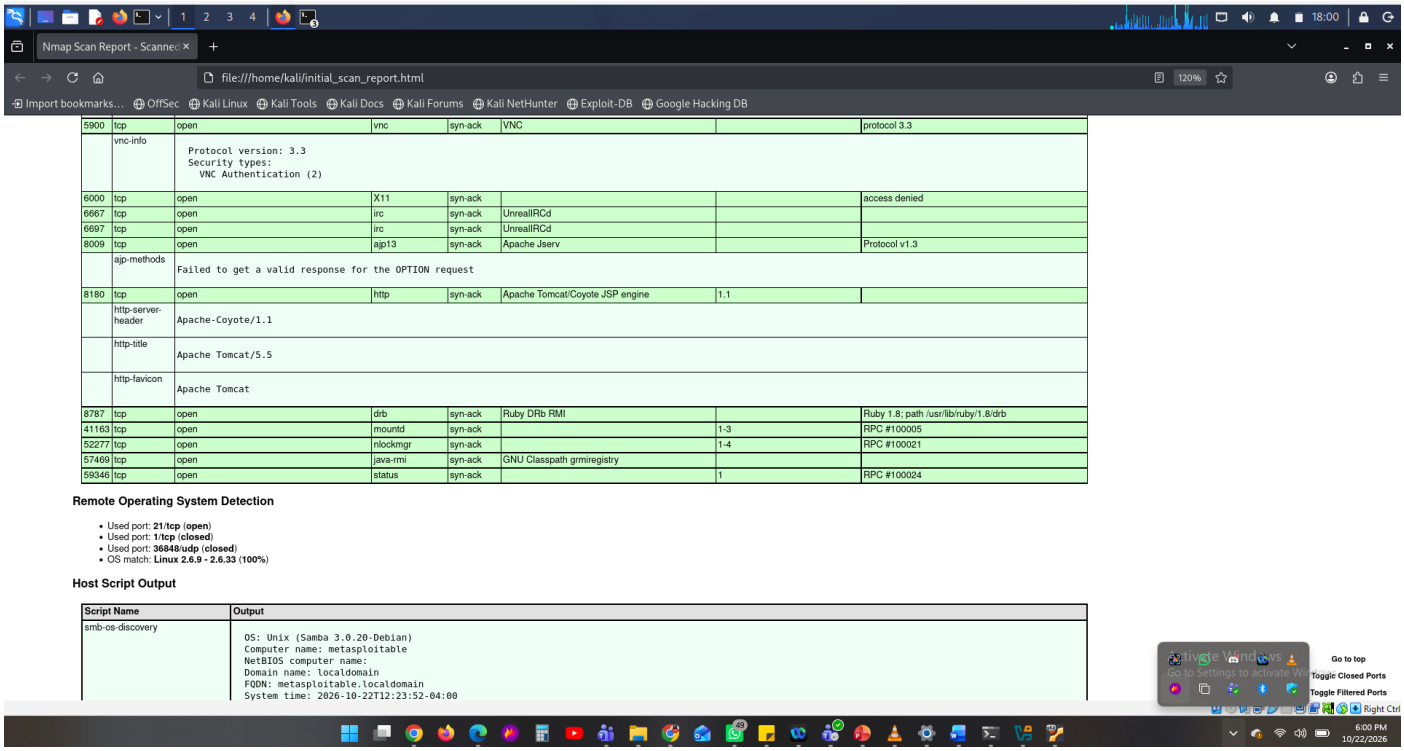
Open initial_scan_report.html in your browser to review the formatted results.







111	tcp	open	rpcbind	syn-ack		2	RPC #100000
	rpcinfo	program version port/proto service 100000 2 111/tcp rpcbind 100000 2 111/udp rpcbind 100003 2,3,4 2049/tcp nfs 100003 2,3,4 2049/udp nfs 100005 1,2,3 41163/tcp mountd 100005 1,2,3 48634/udp mountd 100021 1,3,4 52277/tcp nlockmgr 100021 1,3,4 56849/udp nlockmgr 100024 1 37056/udp status 100024 1 59346/tcp status					
139	tcp	open	netbios-ssn	syn-ack	Samba smbd	3.X - 4.X	workgroup: WORKGROUP
445	tcp	open	netbios-ssn	syn-ack	Samba smbd	3.0.20-Debian	workgroup: WORKGROUP
512	tcp	open	exec	syn-ack	netkit-rsh rexecd		
513	tcp	open	login	syn-ack			
514	tcp	open	shell	syn-ack	Netkit rshd		
1099	tcp	open	java-rmi	syn-ack	GNU Classpath grmiregistry		
1524	tcp	open	bindshell	syn-ack	Metasploitable root shell		
2049	tcp	open	nfs	syn-ack		2-4	RPC #100003
2121	tcp	open	ftp	syn-ack	ProFTPD	1.3.1	
3306	tcp	open	mysql	syn-ack	MySQL	5.0.51a-3ubuntu5	
	mysql-info	Protocol: 10 Version: 5.0.51a-3ubuntu5 Thread ID: 20 Capabilities flags: 43564 Some Capabilities: ConnectWithDatabase, LongColumnFlag, SupportsTransactions, SwitchToSSLAfterHandshake, Support41Auth, SupportsCompression, Speaks41ProtocolNew Status: Autocommit Salt: </u$OC?Sbs>xch^"+P5S					
3632	tcp	open	distccd	syn-ack	distccd	v1	(GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4)
5432	tcp	open	postgresql	syn-ack	PostgreSQL DB	8.3.0 - 8.3.7	
	ssl-date	2026-10-22T16:24:02+00:00; -5s from scanner time.					
	ssl-cert	Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX Not valid before: 2010-03-17T14:07:45 Not valid after: 2010-04-16T14:07:45					
5900	tcp	open	vnc	syn-ack	VNC		protocol 3.3



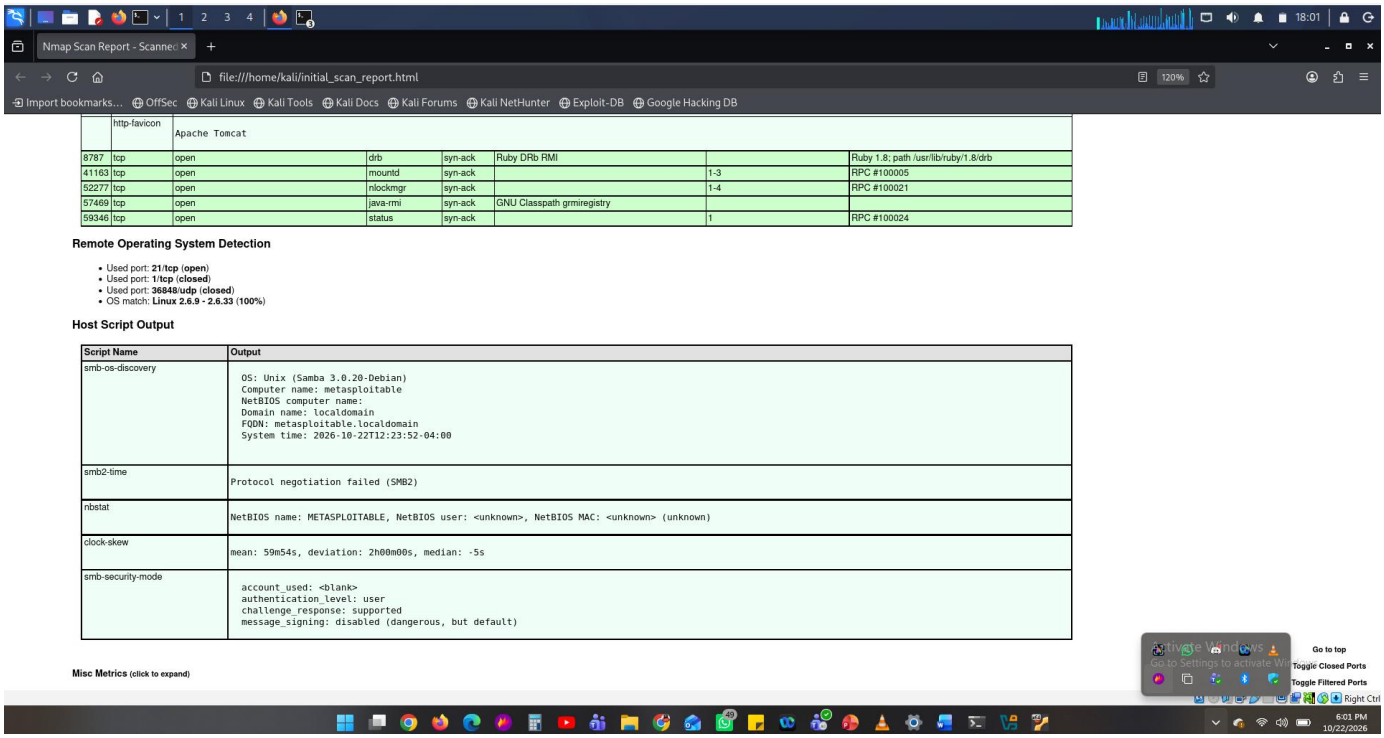
5900	tcp	open	vnc	syn-ack	VNC		protocol 3.3
	vnc-info	Protocol version: 3.3 Security types: VNC Authentication (2)					
6000	tcp	open	X11	syn-ack			access denied
6667	tcp	open	irc	syn-ack	UnrealIRCd		
6697	tcp	open	irc	syn-ack	UnrealIRCd		
8009	tcp	open	ajp13	syn-ack	Apache Jserv		Protocol v1.3
	ajp-methods	Failed to get a valid response for the OPTION request					
8180	tcp	open	http	syn-ack	Apache Tomcat/Coyote JSP engine	1.1	
	http-server-header	Apache-Coyote/1.1					
	http-title	Apache Tomcat/5.5					
	http-favicon	Apache Tomcat					
8787	tcp	open	drb	syn-ack	Ruby DRb RMI		Ruby 1.8; path /usr/lib/ruby/1.8/drb
41163	tcp	open	mountd	syn-ack		1-3	RPC #100005
52277	tcp	open	nlockmgr	syn-ack		1-4	RPC #100021
57469	tcp	open	java-rmi	syn-ack	GNU Classpath grmiregistry		
59346	tcp	open	status	syn-ack		1	RPC #100024

Remote Operating System Detection

- Used port: **21/tcp** (**open**)
- Used port: **1/tcp** (**closed**)
- Used port: **36848/udp** (**closed**)
- OS match: **Linux 2.6.9 - 2.6.33** (**100%**)

Host Script Output

Script Name	Output
smb-os-discovery	OS: Unix (Samba 3.0.20-Debian) Computer name: metasploitable NetBIOS computer name: Domain name: localdomain FQDN: metasploitable.localdomain System time: 2026-10-22T12:23:52-04:00



GRC Question:

Why is knowing which ports are open (e.g., 21/FTP, 23/Telnet) a compliance issue?

(Hint: Think about unnecessary services, attack surface reduction, and compliance with CIS Control 9 and NIST CSF PR.IP-1).

Every open port is a running service, and every running service is a potential entry point. Frameworks expect an organization to know exactly what is exposed and to justify why each service is running. An unnecessary service like Telnet has no business purpose, but it still carries risk: it can be exploited, it needs patching, and it needs monitoring.

- **Unnecessary services and attack surface reduction:** The scan found 30 open ports on a server that only needs a handful. Services like Telnet (23), FTP (21), VNC (5900), and the IRC daemon (6667) add attack surface without supporting any clear business need. Under CIS Control 9 (Limitation and Control of Network Ports, Protocols, and Services in CIS v7), only ports and services with a documented business need should be enabled. Disabling the rest is the cheapest way to remove risk.
- **Insecure and outdated services:** Open ports reveal what is running and at what version. The scan shows vsftpd 2.3.4 (a version with a known backdoor), anonymous FTP login allowed, Telnet and FTP sending data in plain text, SMTP supporting obsolete SSLv2, and Tomcat 5.5. Each of these is a policy violation, and not just a technical flaw.

- **NIST CSF PR.IP-1 (baseline configuration):** Organizations are expected to maintain a secure baseline configuration that includes least functionality, meaning systems run only what they are meant to. A server with 30 open ports has clearly drifted from any reasonable baseline, which signals a gap in configuration management.
- **Asset inventory and monitoring:** One cannot defend, patch, or audit services one does not know about. A port scan gives auditors evidence of the actual state of the system, which they can compare against what policy says it should be. Any difference between the two is a finding.

Phase 2:Vulnerability Identification

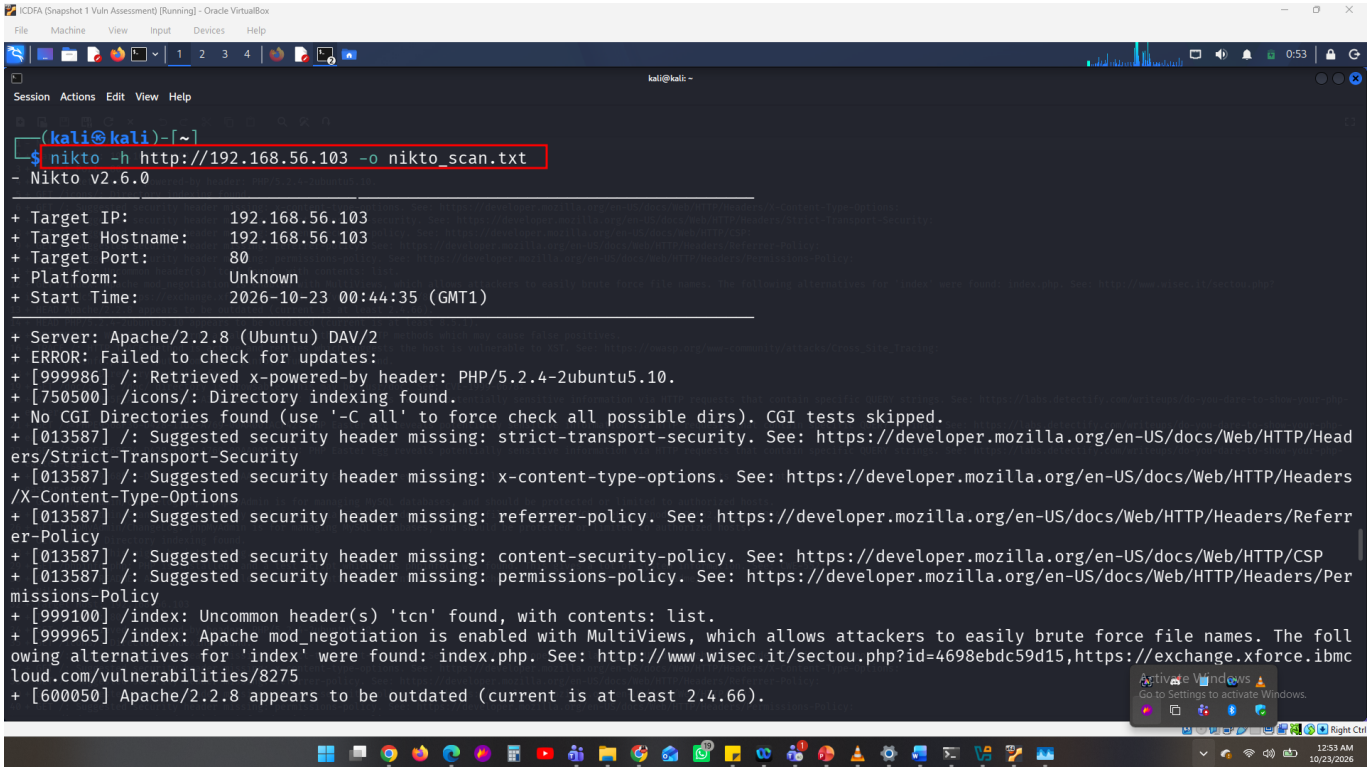
Step 3: Analyzing Nmap Output

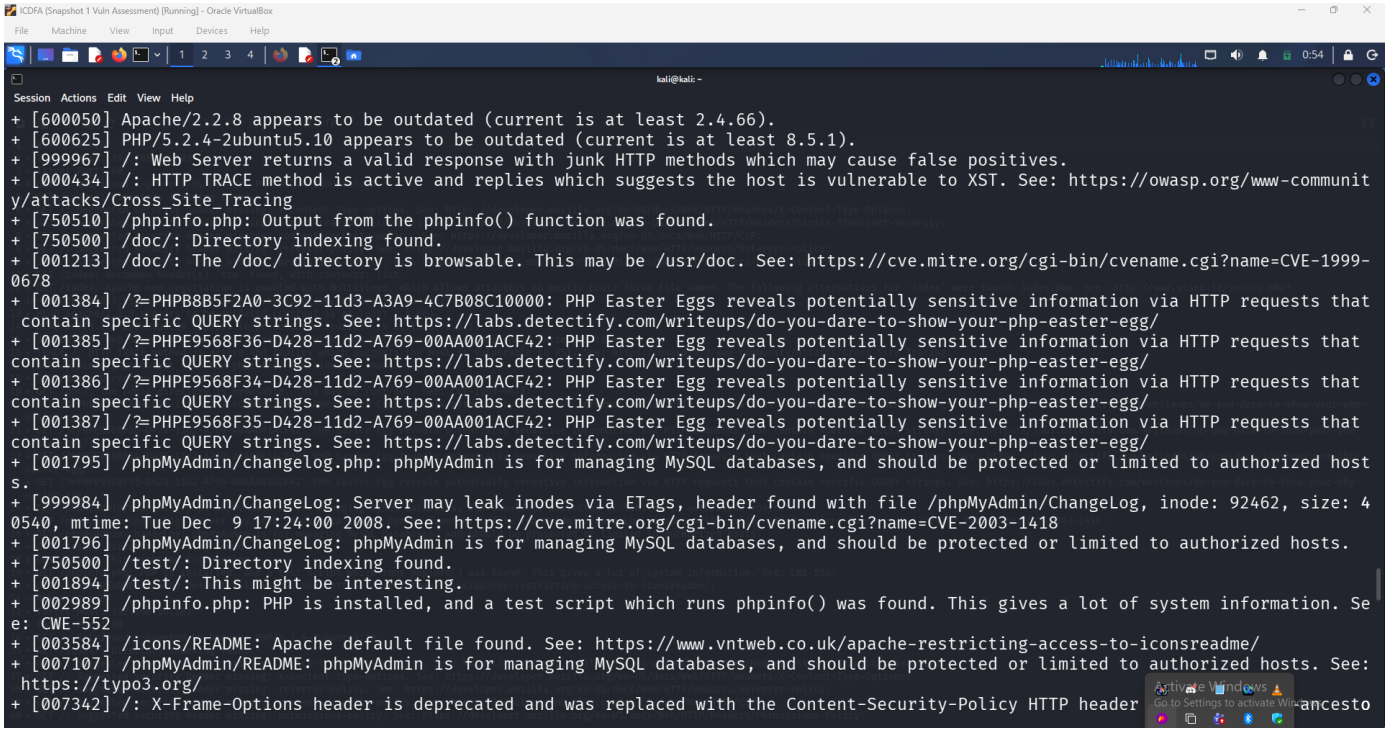
- **Task:** Review initial_scan.nmap and the HTML report. Identify:
  - Service versions (e.g., vsftpd 2.3.4).
  - Interesting script outputs (e.g., SSH host keys, HTTP headers).
  - Note every service and its version for further analysis.

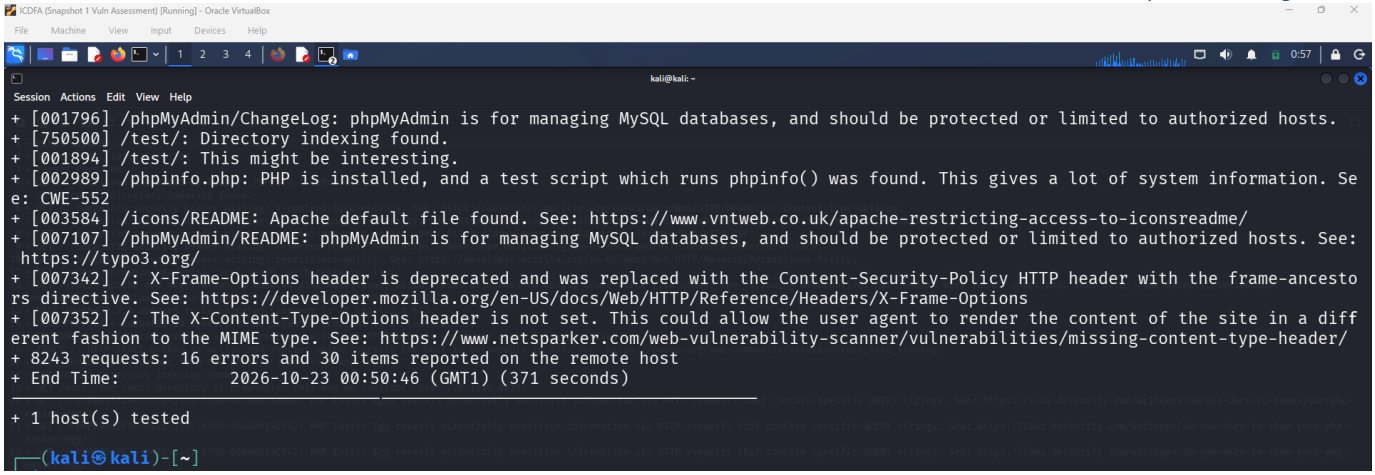
S/No	Themes	Service Ports and Versions	Why it matters
1	Known backdoor or exploitable versions	21 vsftpd 2.3.4, 6667/6697 UnrealIRCd, 3632 distccd 4.2.4, 445 Samba 3.0.20	These versions have well-known remote-compromise issues (CVE-2011-2523 for vsftpd, CVE-2010-2075 for some UnrealIRCd builds, CVE-2004-2687 for distccd, CVE-2007-2447 for Samba 3.0.20). Confirm them with Nuclei before citing them as findings.
2	Plaintext or legacy remote access	23 Telnet, 512/513/514 rexec, rlogin, rsh, 5900 VNC	Credentials cross the network unencrypted; these protocols are obsolete.
3	Outright Backdoor	1524 “Metasploitable root shell”	An open root shell with no authentication
4	Weak authentication or access	21 anonymous FTP login allowed, 2049 NFS	Unauthenticated access to files
5	Outdated software	OpenSSH 4.7p1, Apache 2.2.8, BIND 9.4.2, MySQL 5.0.51a, PostgreSQL 8.3.x, Tomcat 5.5, ProFTPD 1.3.1	All are far past end of life so patch management failure
6	Weak crypto	25 SMTP supports SSLv2 with export-grade ciphers, and the certificate expired in 2010	Fails encryption standards
7	SMB Hardening	139/445 message signing disabled	Allows relay and tampering attacks
8	Excess exposure	Databases (3306, 5432), X11 (6000), Java RMI (1099, 57469), DRb (8787), AJP (8009), and several RPC ports	Internal services reachable from the network with no business need shown

Step 4: Web Application Assessment

- **Task:** Scan the web server for common vulnerabilities.
- **Command (Nikto):** nikto -h http://<TARGET_IP> -o nikto_scan.txt
- **Action:**
  - Open http://<TARGET_IP> in Firefox and explore any applications (e.g., PHP, TWiki).
  - Manually inspect for obvious issues (e.g., default pages, verbose errors).



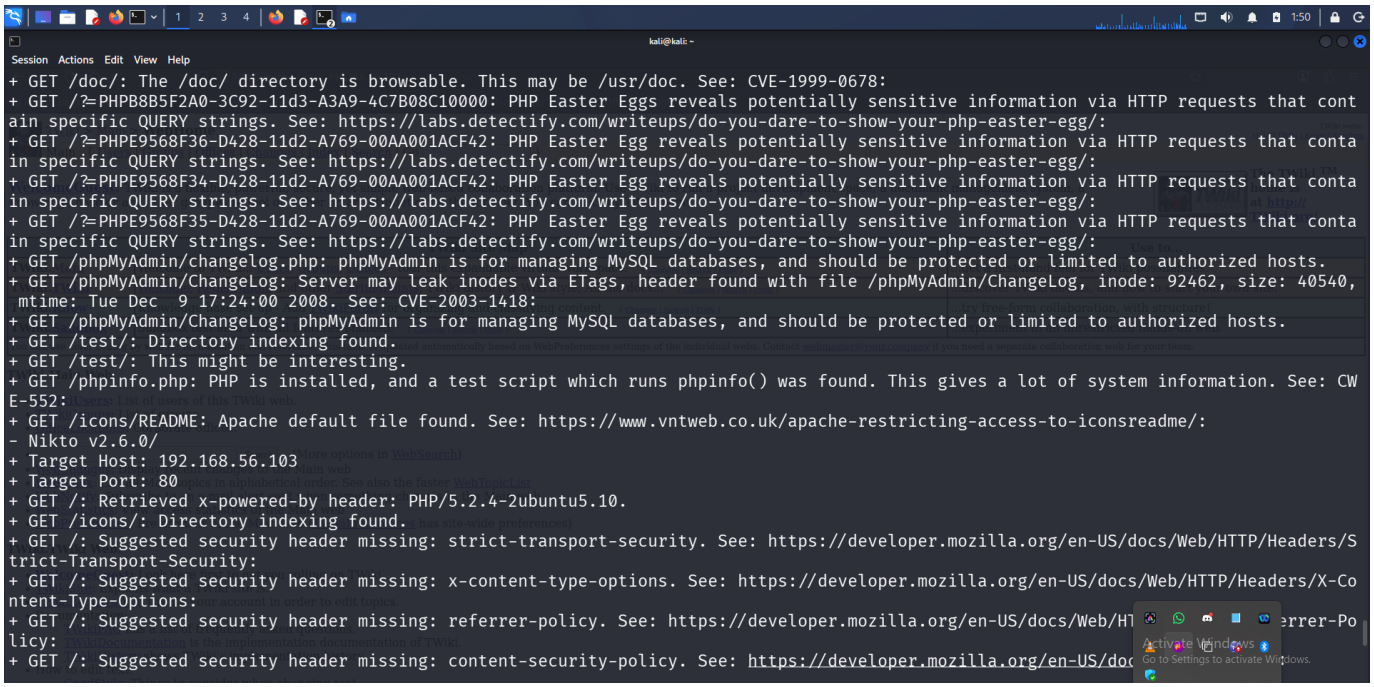




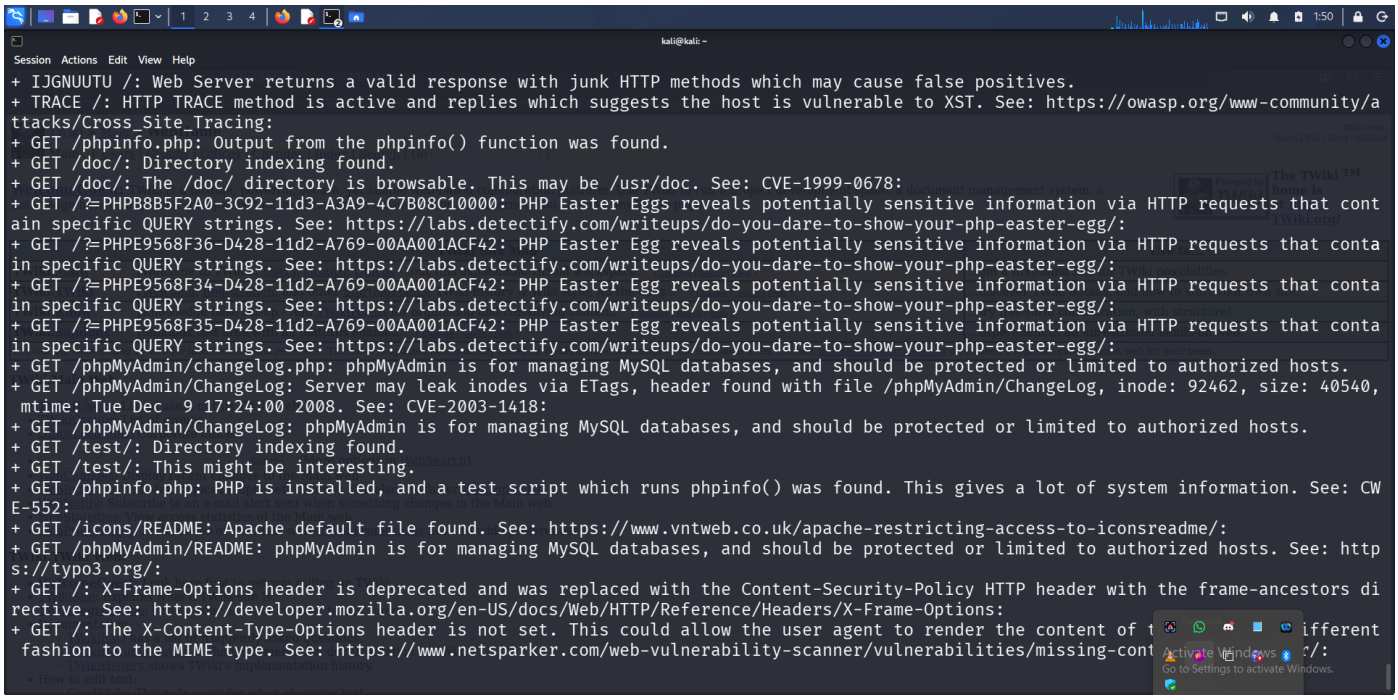
```
+ [001796] /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [750500] /test/: Directory indexing found.
+ [001894] /test/: This might be interesting.
+ [002989] /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. Se
e: CWE-552
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ [007107] /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See:
 https://typo3.org/
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancesto
rs directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a diff
erent fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8243 requests: 16 errors and 30 items reported on the remote host
+ End Time:           2026-10-23 00:50:46 (GMT1) (371 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested

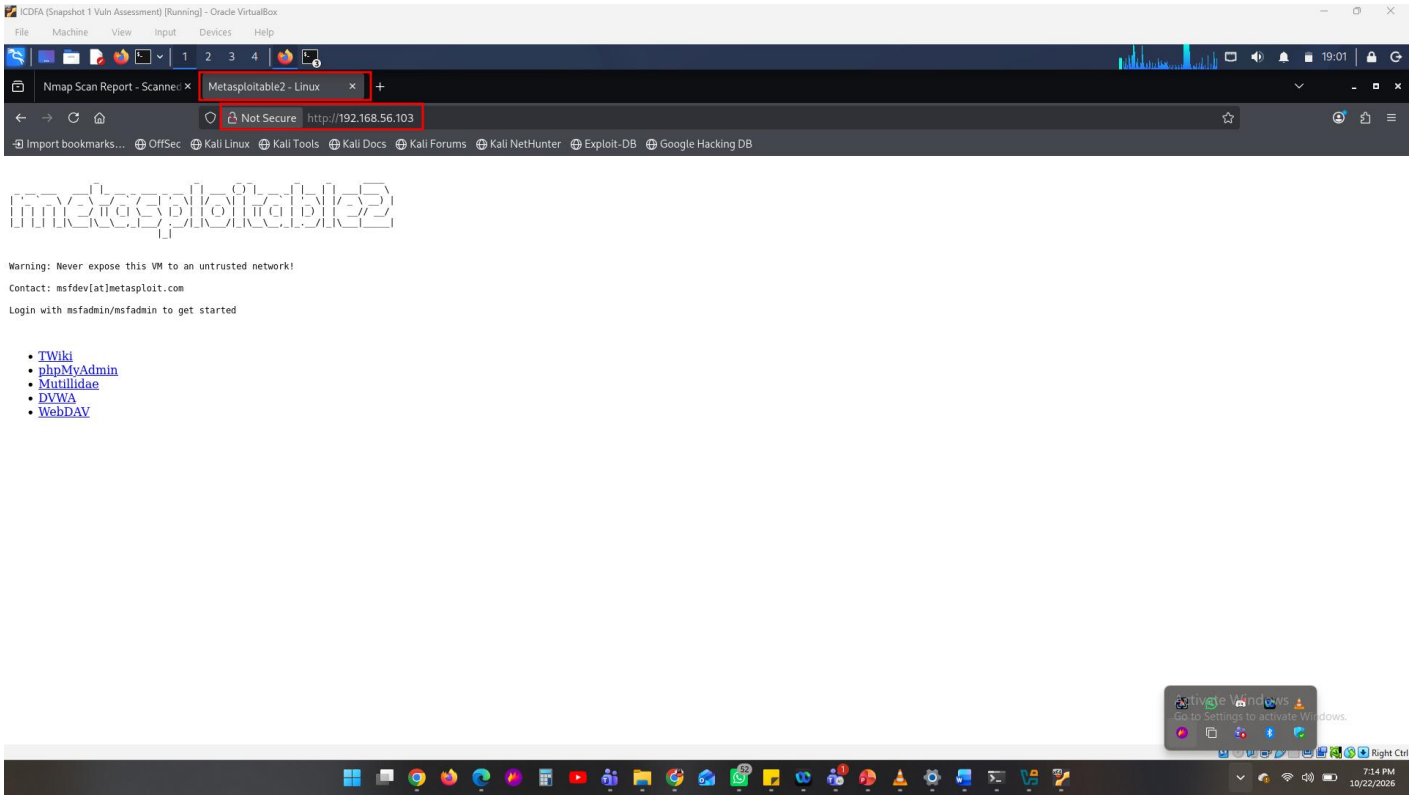
┌──(kali㉿kali)-[~]
```

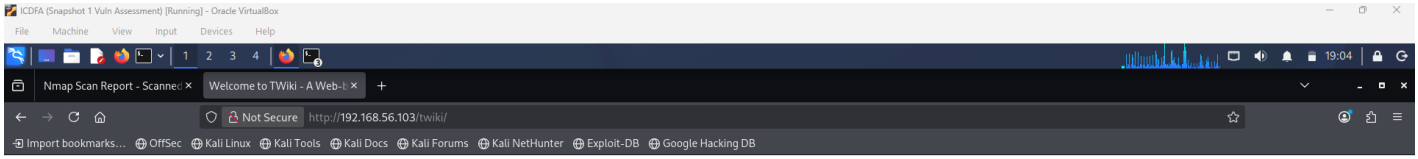
```
┌──(kali㉿kali)-[~]
└─$ cat nikto_scan.txt
- Nikto v2.6.0/
+ Target Host: 192.168.56.103
+ Target Port: 80
+ GET /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ GET /icons/: Directory indexing found.
+ GET /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Co
ntent-Type-Options:
+ GET /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/S
trict-Transport-Security:
+ GET /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP:
+ GET /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Po
licy:
+ GET /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissi
ons-Policy:
+ GET /index: Uncommon header(s) 'tcn' found, with contents: list.
+ GET /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following
 alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.
com/vulnerabilities/8275:
+ HEAD Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ HEAD PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ BROQDNIW /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ TRACE /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/a
ttacks/Cross_Site_Tracing:
+ GET /phpinfo.php: Output from the phpinfo() function was found.
+ GET /doc/: Directory indexing found.
+ GET /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: CVE-1999-0678:
+ GET /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via H                    nat cont
```



```
+ GET /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: CVE-1999-0678:
+ GET /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that cont
ain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/:
+ GET /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that conta
in specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/:
+ GET /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that conta
in specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/:
+ GET /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that conta
in specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/:
+ GET /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ GET /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540,
 mtime: Tue Dec  9 17:24:00 2008. See: CVE-2003-1418:
+ GET /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ GET /test/: Directory indexing found.
+ GET /test/: This might be interesting.
+ GET /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CW
E-552:
+ GET /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/:
- Nikto v2.6.0/
+ Target Host: 192.168.56.103
+ Target Port: 80
+ GET /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ GET /icons/: Directory indexing found.
+ GET /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/S
trict-Transport-Security:
+ GET /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Co
ntent-Type-Options:
+ GET /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HT                    errer-Po
licy:
+ GET /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/doc
```

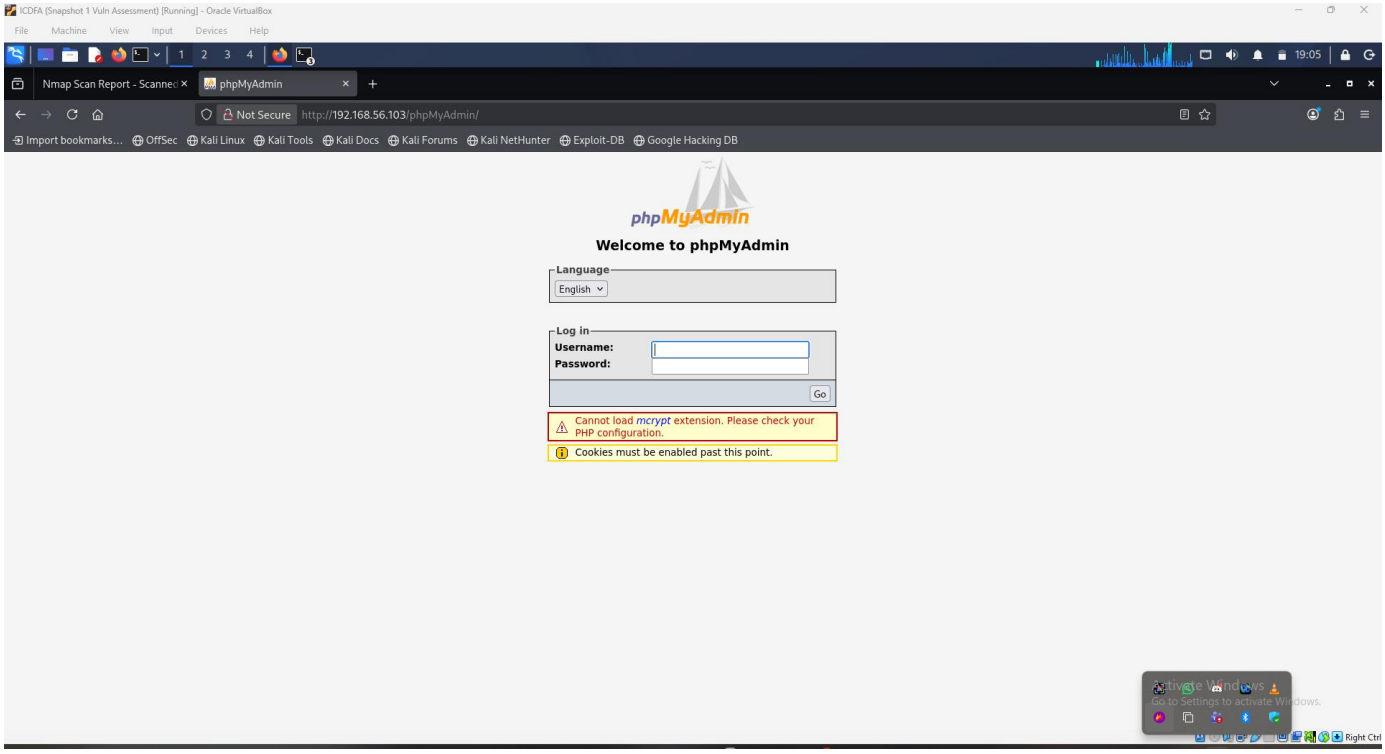

kali@kali: ~
Session Actions Edit View Help
+ IJGNUUTU /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ TRACE /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing:
+ GET /phpinfo.php: Output from the phpinfo() function was found.
+ GET /doc/: Directory indexing found.
+ GET /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: CVE-1999-0678:
+ GET /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/:
+ GET /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/:
+ GET /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/:
+ GET /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/:
+ GET /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ GET /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 17:24:00 2008. See: CVE-2003-1418:
+ GET /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ GET /test/: Directory indexing found.
+ GET /test/: This might be interesting.
+ GET /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552:
+ GET /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/:
+ GET /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/:
+ GET /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options:
+ GET /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of t ifferent fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-cont :/:

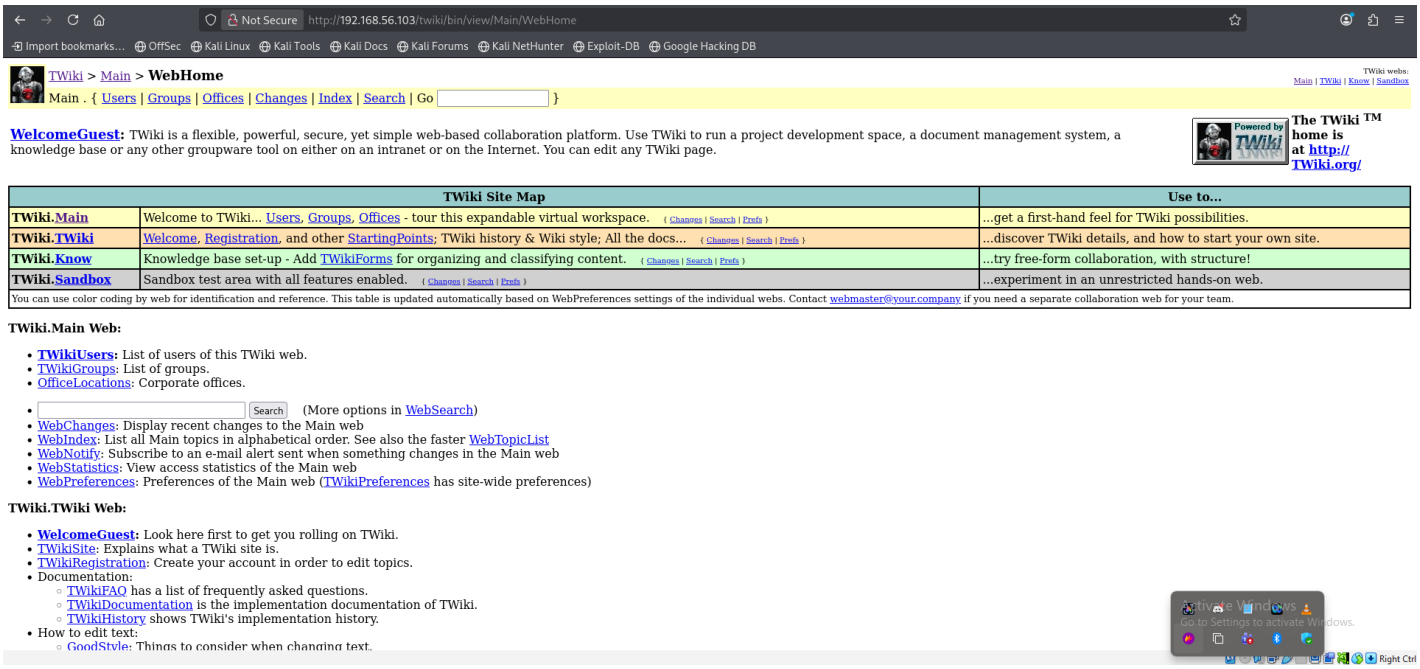

ICDFA (Snapshot 1 Vuln Assessment) [Running] - Oracle VirtualBox
Nmap Scan Report - Scanned
Metasploitable2 - Linux
Not Secure http://192.168.56.103
Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started
TWiki
phpMyAdmin
Mutillidae
DVWA
WebDAV

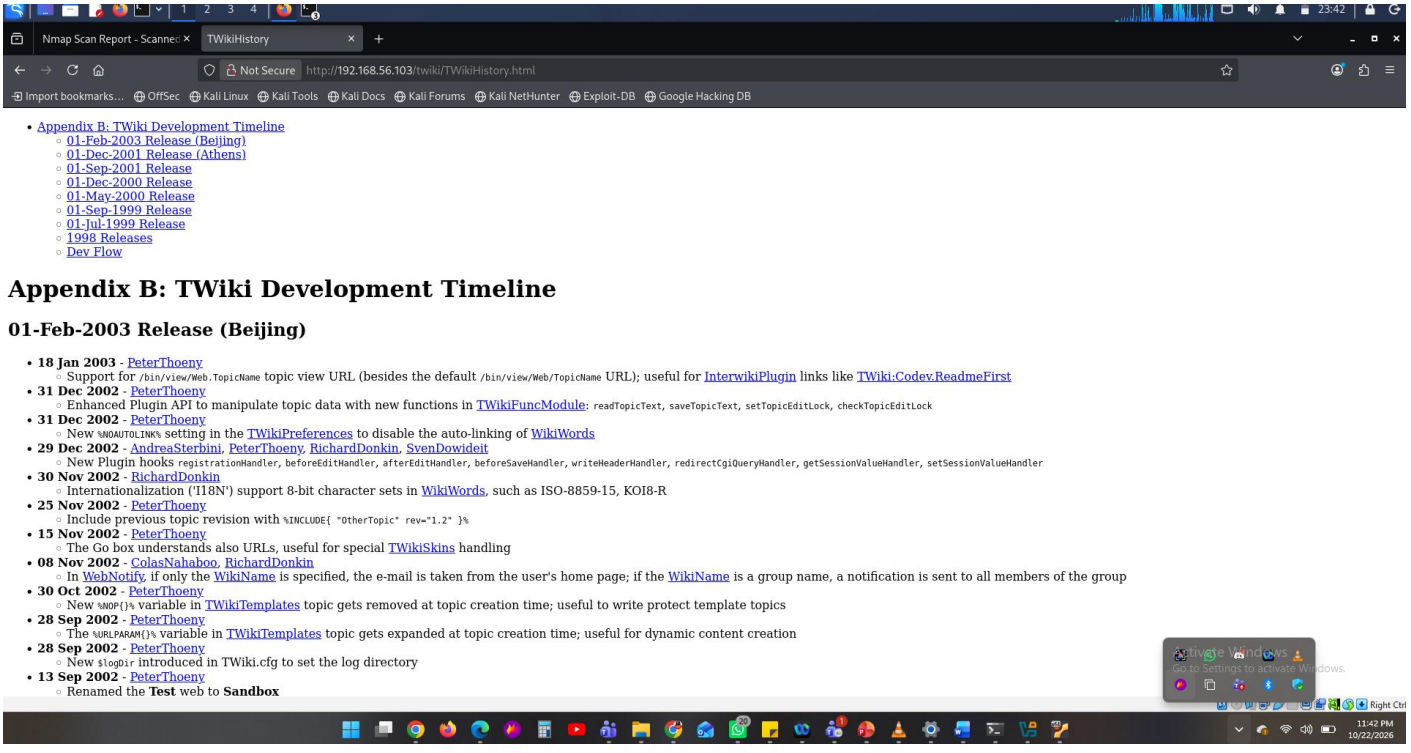


Welcome to TWiki

- readme.txt
- license.txt
- TWikiDocumentation.html
- TWikiHistory.html
- Lets get started with this web based collaboration platform




Not Secure
http://192.168.56.103/twiki/bin/view/Main/WebHome
Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
TWiki > Main > WebHome
Main . { Users | Groups | Offices | Changes | Index | Search | Go }
TWiki webs:
Main | TWiki | Know | SandBox
WelcomeGuest: TWiki is a flexible, powerful, secure, yet simple web-based collaboration platform. Use TWiki to run a project development space, a document management system, a knowledge base or any other groupware tool on either on an intranet or on the Internet. You can edit any TWiki page.
Powered by TWiki
The TWiki TM home is at http://TWiki.org/
TWiki Site Map
Use to...
TWiki.Main
Welcome to TWiki... Users, Groups, Offices - tour this expandable virtual workspace.
...get a first-hand feel for TWiki possibilities.
TWiki.TWiki
Welcome, Registration, and other StartingPoints; TWiki history & Wiki style; All the docs...
...discover TWiki details, and how to start your own site.
TWiki.Know
Knowledge base set-up - Add TWikiForms for organizing and classifying content.
...try free-form collaboration, with structure!
TWiki.Sandbox
Sandbox test area with all features enabled.
...experiment in an unrestricted hands-on web.
You can use color coding by web for identification and reference. This table is updated automatically based on WebPreferences settings of the individual webs. Contact webmaster@your.company if you need a separate collaboration web for your team.
TWiki.Main Web:
TWikiUsers: List of users of this TWiki web.
TWikiGroups: List of groups.
OfficeLocations: Corporate offices.
Search
(More options in WebSearch)
WebChanges: Display recent changes to the Main web
WebIndex: List all Main topics in alphabetical order. See also the faster WebTopicList
WebNotify: Subscribe to an e-mail alert sent when something changes in the Main web
WebStatistics: View access statistics of the Main web
WebPreferences: Preferences of the Main web (TWikiPreferences has site-wide preferences)
TWiki.TWiki Web:
WelcomeGuest: Look here first to get you rolling on TWiki.
TWikiSite: Explains what a TWiki site is.
TWikiRegistration: Create your account in order to edit topics.
Documentation:
TWikiFAQ has a list of frequently asked questions.
TWikiDocumentation is the implementation documentation of TWiki.
TWikiHistory shows TWiki's implementation history.
How to edit text:
GoodStyle: Things to consider when changing text.
Activate Windows
Go to Settings to activate Windows.
Right Ctrl


Nmap Scan Report - Scanned
TWikiHistory
Not Secure
http://192.168.56.103/twiki/TWikiHistory.html
Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
Appendix B: TWiki Development Timeline
01-Feb-2003 Release (Beijing)
01-Dec-2001 Release (Athens)
01-Sep-2001 Release
01-Dec-2000 Release
01-May-2000 Release
01-Sep-1999 Release
01-Jul-1999 Release
1998 Releases
Dev Flow
Appendix B: TWiki Development Timeline
01-Feb-2003 Release (Beijing)
18 Jan 2003 - PeterThoeny
Support for /bin/view/Web.TopicName topic view URL (besides the default /bin/view/Web/TopicName URL); useful for InterwikiPlugin links like TWiki:Codev.ReadmeFirst
31 Dec 2002 - PeterThoeny
Enhanced Plugin API to manipulate topic data with new functions in TWikiFuncModule: readTopicText, saveTopicText, setTopicEditLock, checkTopicEditLock
31 Dec 2002 - PeterThoeny
New %NOAUTOLINK% setting in the TWikiPreferences to disable the auto-linking of WikiWords
29 Dec 2002 - AndreaSterbini, PeterThoeny, RichardDonkin, SvenDowideit
New Plugin hooks registrationHandler, beforeEditHandler, afterEditHandler, beforeSaveHandler, writeHeaderHandler, redirectCgiQueryHandler, getSessionValueHandler, setSessionValueHandler
30 Nov 2002 - RichardDonkin
Internationalization ('I18N') support 8-bit character sets in WikiWords, such as ISO-8859-15, KOI8-R
25 Nov 2002 - PeterThoeny
Include previous topic revision with %INCLUDE{ "OtherTopic" rev="1.2" }%
15 Nov 2002 - PeterThoeny
The Go box understands also URLs, useful for special TWikiSkins handling
08 Nov 2002 - ColasNahaboo, RichardDonkin
In WebNotify, if only the WikiName is specified, the e-mail is taken from the user's home page; if the WikiName is a group name, a notification is sent to all members of the group
30 Oct 2002 - PeterThoeny
New %NOP{}% variable in TWikiTemplates topic gets removed at topic creation time; useful to write protect template topics
28 Sep 2002 - PeterThoeny
The %URLPARAM{}% variable in TWikiTemplates topic gets expanded at topic creation time; useful for dynamic content creation
28 Sep 2002 - PeterThoeny
New $logDir introduced in TWiki.cfg to set the log directory
13 Sep 2002 - PeterThoeny
Renamed the Test web to Sandbox
Activate Windows
Go to Settings to activate Windows.
Right Ctrl
11:42 PM
10/22/2026

Nikto Findings / Analysis

S/No	Findings	Why it matters
1.	Apache 2.2.8 with DAV/2	Released in 2008 and long out of support so there is a patch management gap
2.	PHP 5.2.4 leaked via the ***x-Powered-By*** header	Outdated runtime, and the version disclosed helps attackers pick exploits
3.	Directory indexing on **/icons/**	Lets anyone browse directory contents. Low severity on its own.
4.	Missing security headers (CSP, HSTS, X-Content-Type-Options, Referrer-Policy, Permissions-Policy)	Weak web hardening, so the site is more exposed to XSS and downgrade attacks.
5.	***mod_negotiation*** with MultiViews enabled	Lets attackers guess hidden file names
6.	HTTP TRACE enabled	Can enable cross-site tracing (XST) to steal credentials or cookies.
7.	***/phpinfo.php*** exposed	Reveals PHP config, paths, and modules to anyone (CWE-552).
8.	***/doc/ and /test/*** directory indexing	Exposes internal files and test directories have no place on a production like server
9	phpMyAdmin ***ChangeLog*** accessible	Discloses the exact phpMyAdmin version and confirms the admin tool isn't restricted by host
10	ETag inode leak	Minor information disclosure (CVE-2003-1418)
11	PHP "Easter egg" query strings	Another sign of old PHP 5.2.4 leaking details.
12.	Apache and PHP flagged outdated	Nikto confirms what nmap found

Firefox Screenshots Findings

1. **Default password on homepage**

The metasploitable home page says "Login with msfadmin / msfadmin to get started". This is a default password shown to everyone. It proves the system is using weak authentication which can be linked to CIS 4.7 (managing default accounts).

2. **Exposed Apps**

TWiki, phpMyAdmin, Mutillidae, DVWA, and WebDAV are all reachable from the browser. The last three are known to be deliberately vulnerable practice apps. The main issue for management is that a development server like this is exposing an admin panel (phpMyAdmin) open for anyone to access with no restrictions.

3. phpMyAdmin shows an error

The "Cannot load mcrypt extension" message is a kind of detailed error tells an attacker that the server is not set up properly as it reveals misconfiguration. This is OWASP A05 - Security Misconfiguration.

4. TWiki is a default installation

Files like *readme.txt* and *license.txt* are exposed which depicts a default installation. Upon checking *TWikiHistory.html*, the TWiki Development Timeline ranges from 1998-2003 and old versions of TWiki have been known to have security issues.

GRC Context : Web Applications are high-risk vectors. This aligns with OWASP Top 10 and PCI DSS Requirement 6.

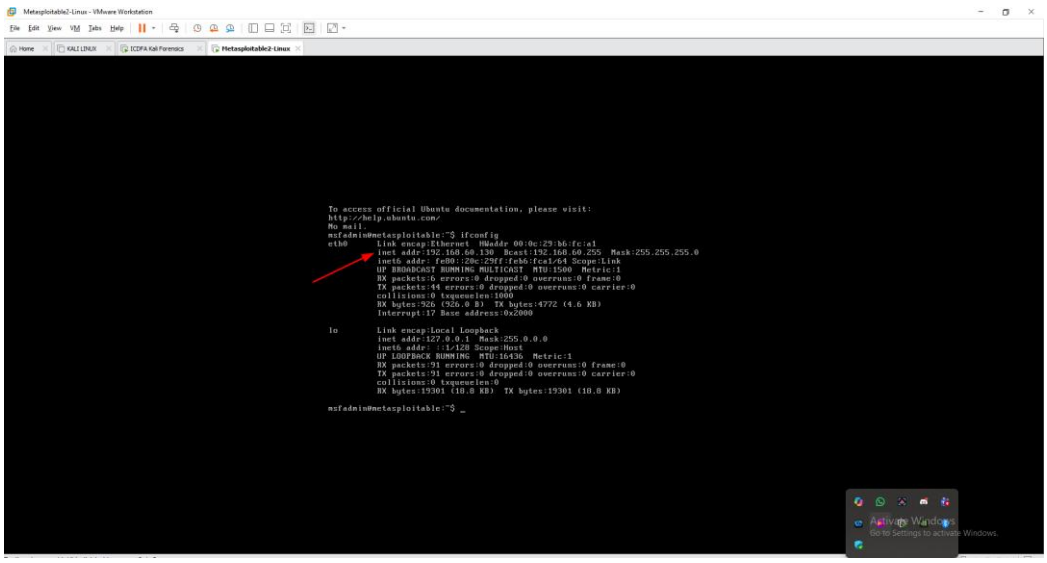
Web applications are among the most exposed parts of an environment because they are reachable by anyone on the network and often run complex, third-party code. The Nikto scan and manual inspection of the Metasploitable 2 web server found outdated Apache (2.2.8) and PHP (5.2.4) versions, exposed administrative interfaces (phpMyAdmin), default files and directory listings, an exposed phpinfo() page, an enabled HTTP TRACE method, missing security headers, and default credentials published on the landing page. These map to OWASP Top 10 Security Misconfiguration and outdated or vulnerable components, and would fail PCI DSS Requirement 6 (patching and securing public-facing applications) and Requirement 2 (secure configuration) if the system were in scope. The business impact is data exposure, unauthorized access to databases, and a foothold for attackers to move deeper into the network.

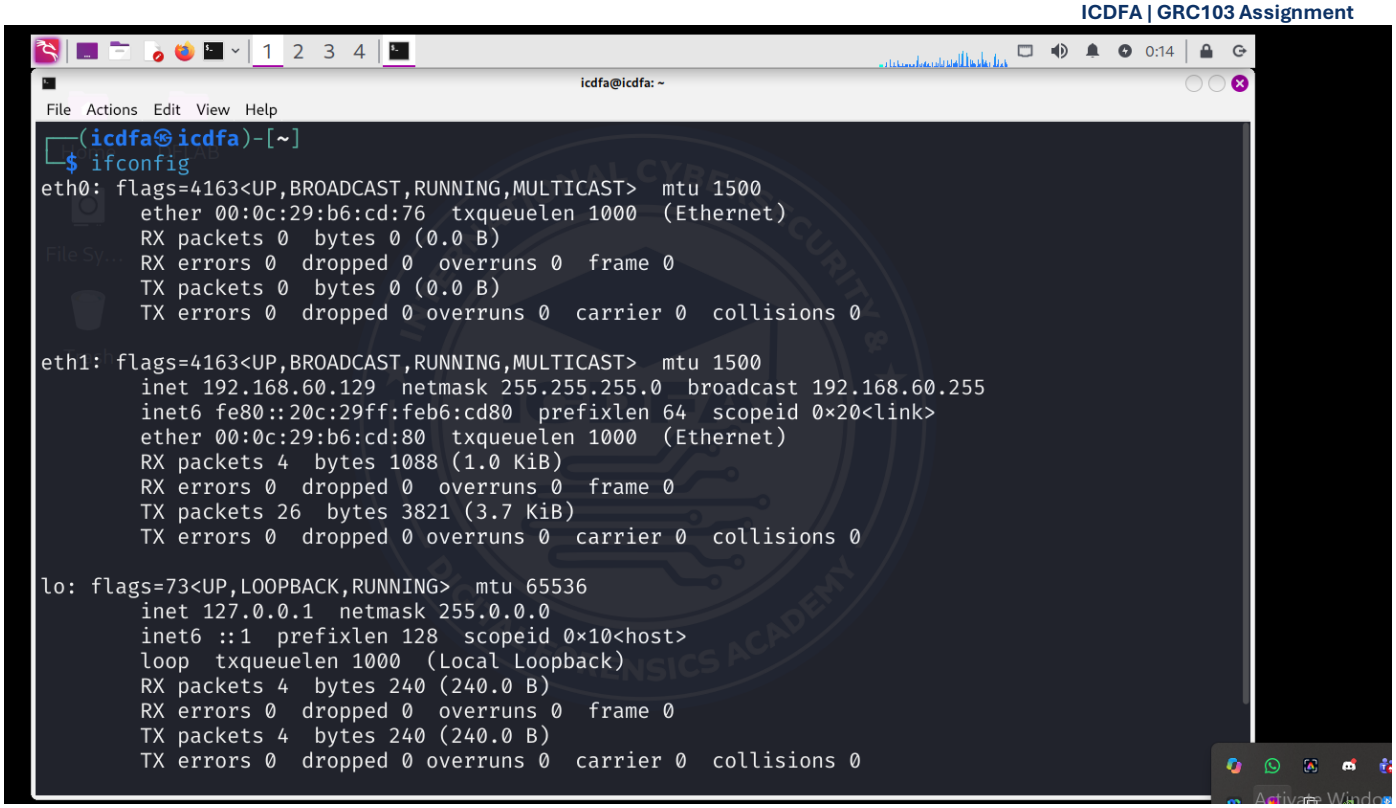
Step 5: Focused Vulnerability Scanning

Task: Nuclei was used to scan for known vulnerabilities based on identified services.

Note on environment change from Virtual Box (VB) to VMWare (VMW)

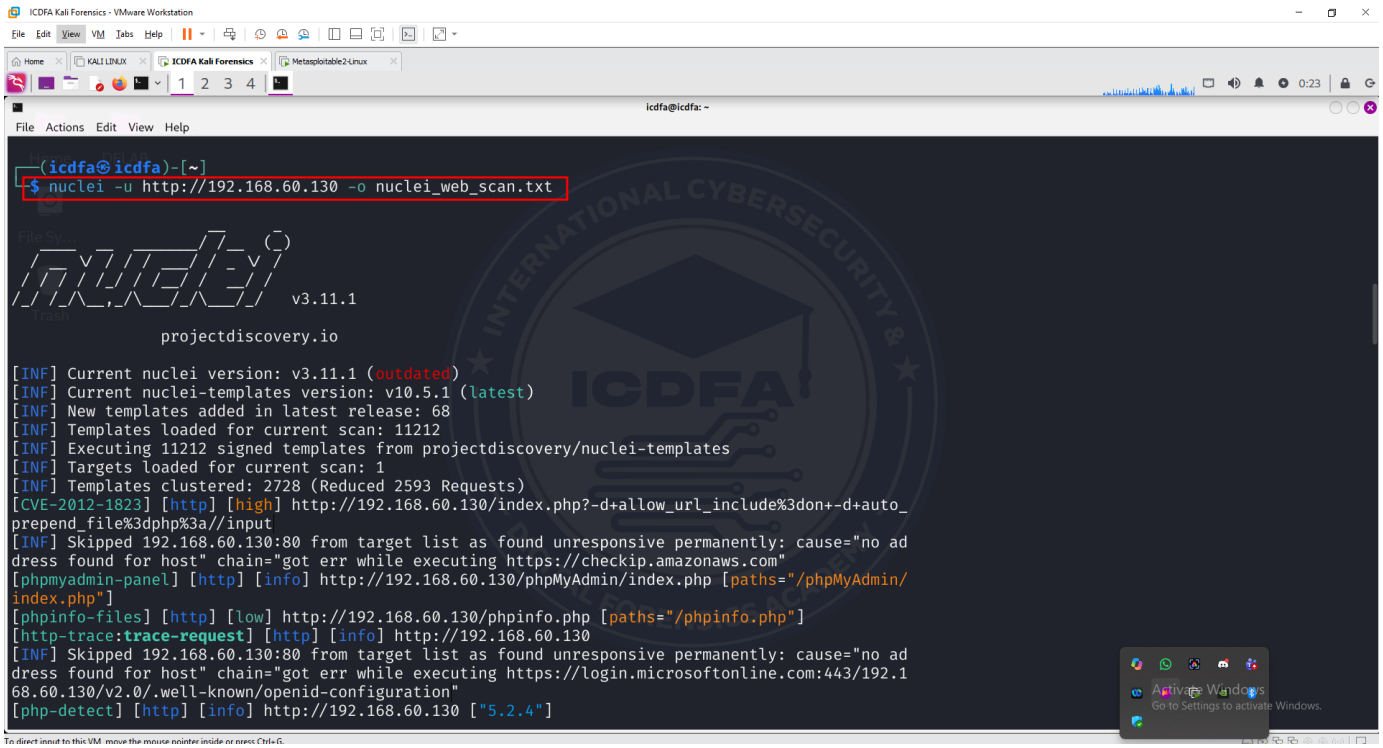
Nmap and Nikto ran on VirtualBox (Kali 192.168.56.104, target 192.168.56.103), and Nuclei ran on VMware (Kali 192.168.60.129, target 192.168.60.130) after VirtualBox networking issues prevented Kali from reaching the internet to download Nuclei's templates.

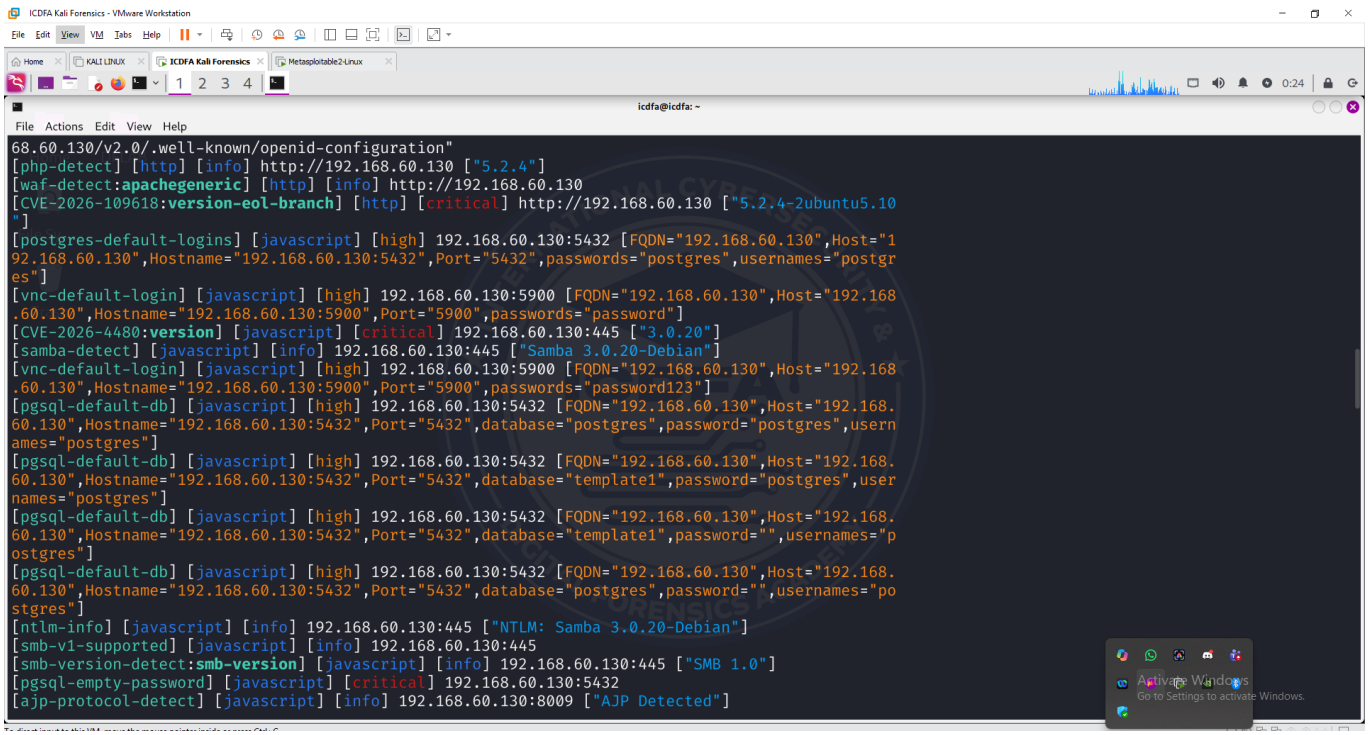


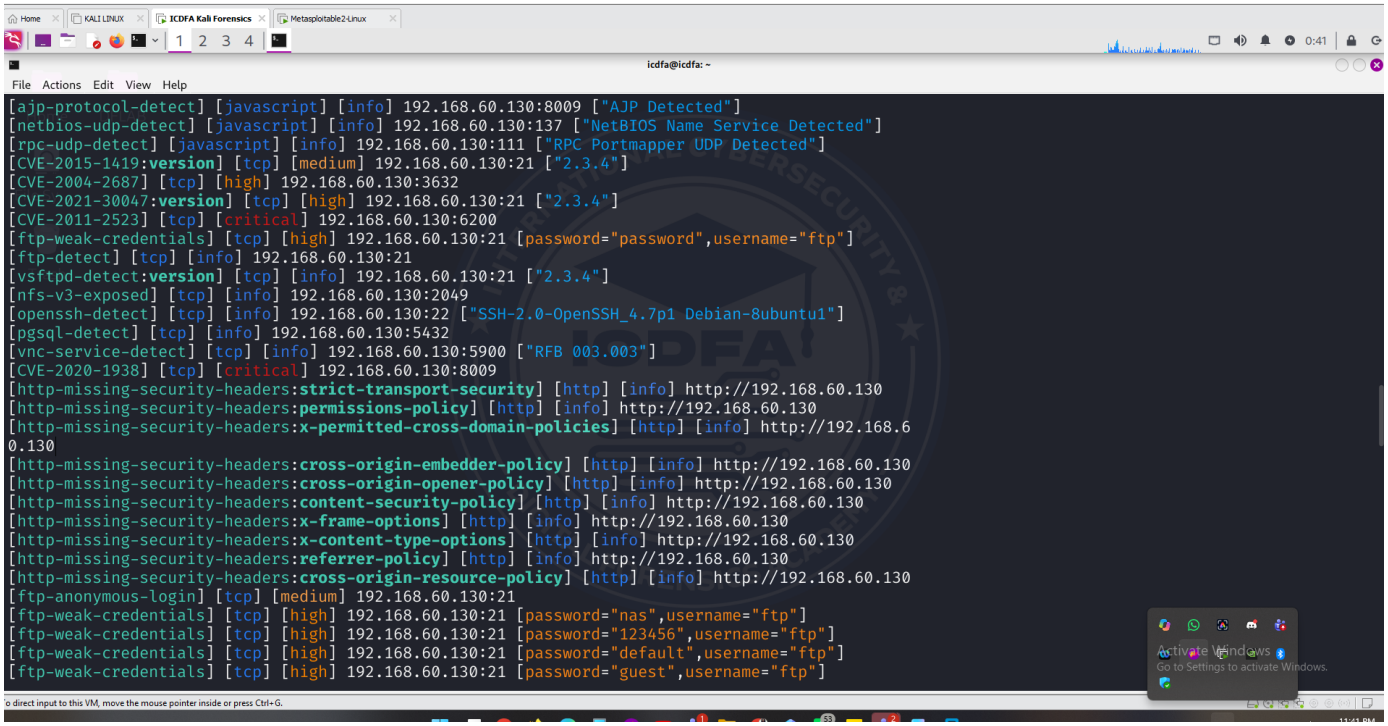


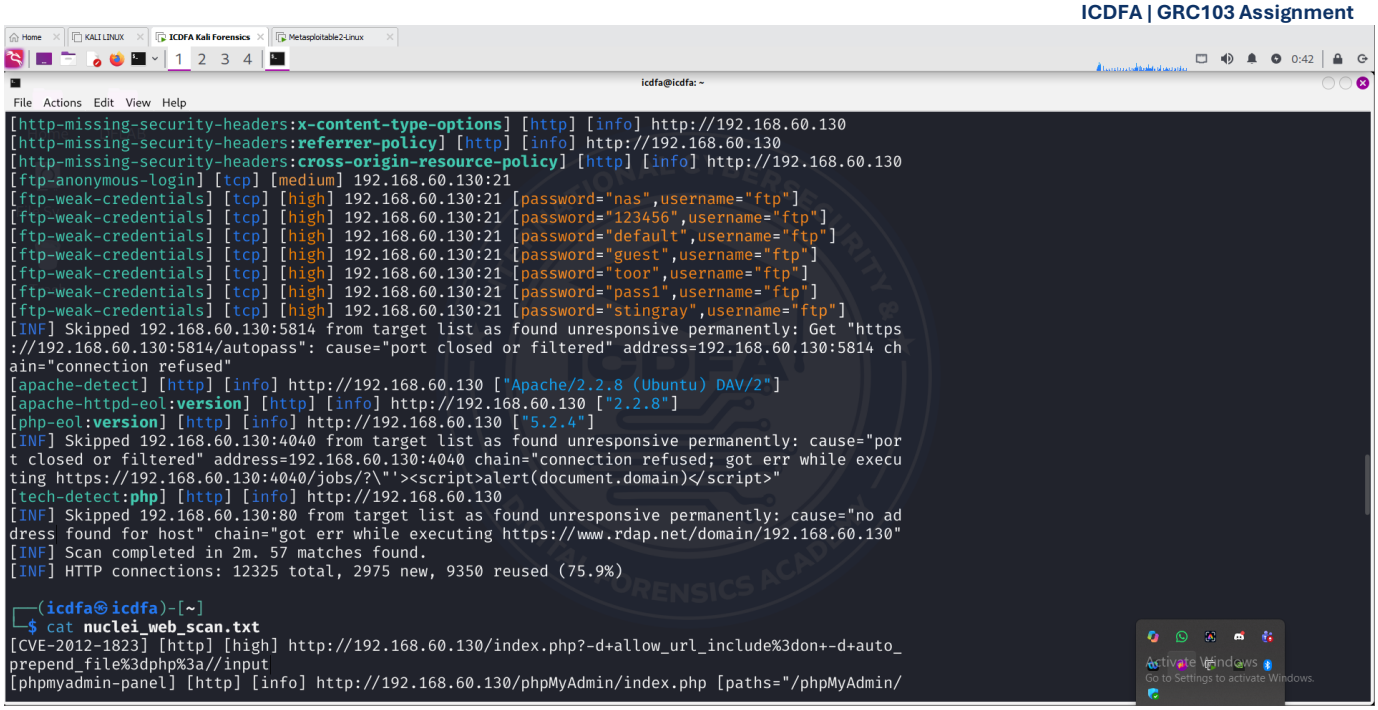
For web applications

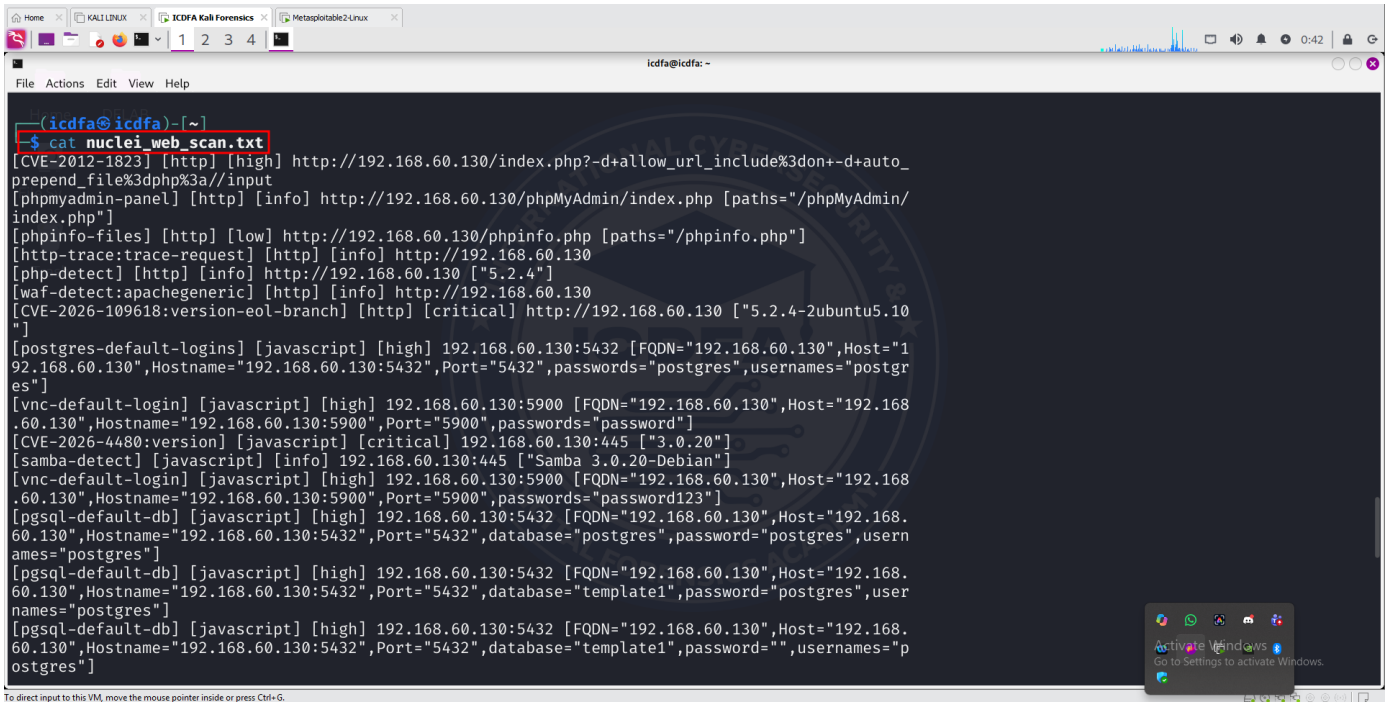
Command: nuclei -u http://<TARGET_IP> -o nuclei_web_scan.txt

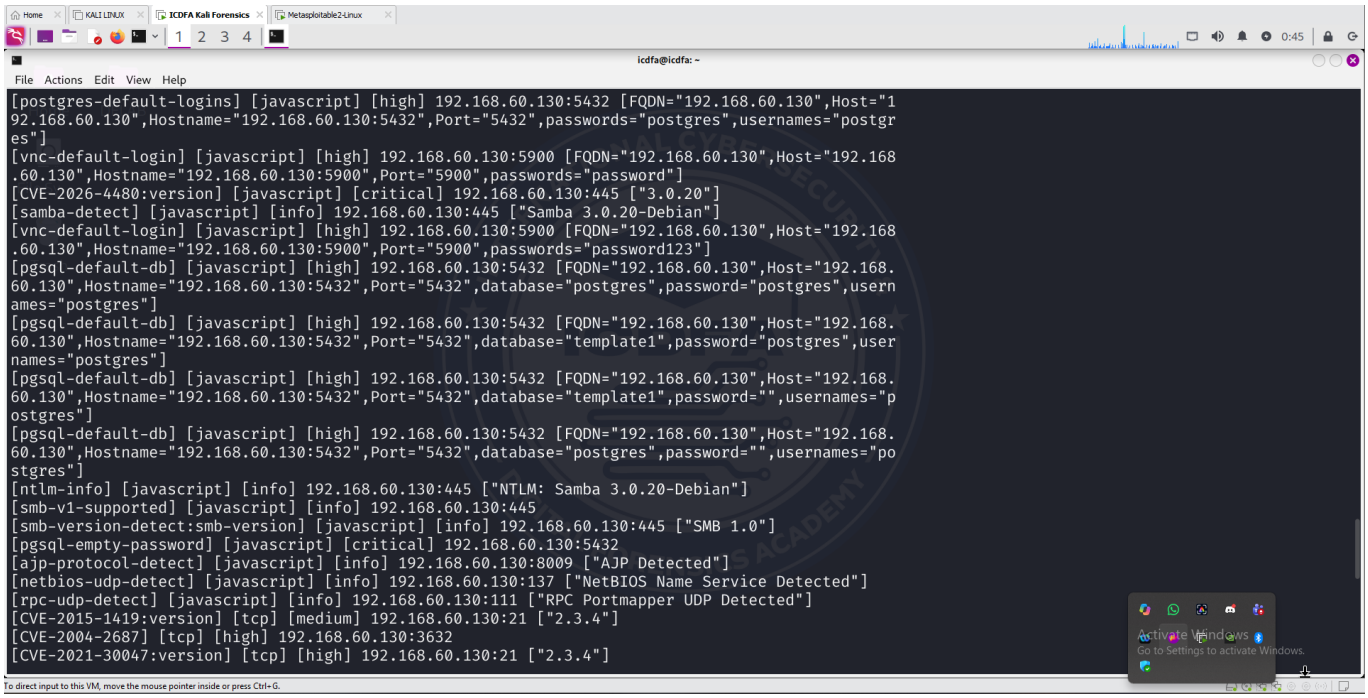


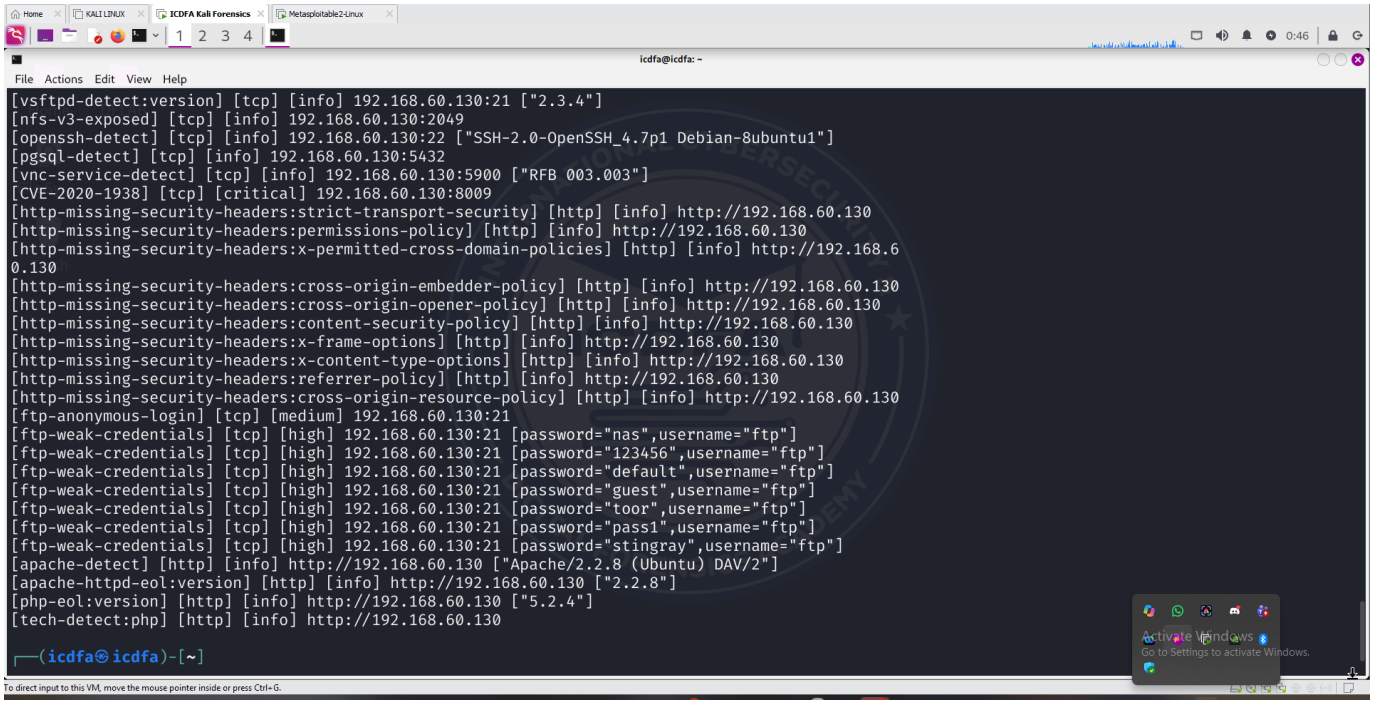

ICDFA Kali Forensics - VMware Workstation
File Edit View VM Tabs Help
Home
KALI LINUX
ICDFA Kali Forensics
Metasploitable2-Linux
1 2 3 4
0:24
icdfa@icdfa: ~
File Actions Edit View Help
68.60.130/v2.0/.well-known/openid-configuration"
[php-detect] [http] [info] http://192.168.60.130 ["5.2.4"]
[waf-detect:apachegeneric] [http] [info] http://192.168.60.130
[CVE-2026-109618:version-eol-branch] [http] [critical] http://192.168.60.130 ["5.2.4-2ubuntu5.10
"]
[postgres-default-logins] [javascript] [high] 192.168.60.130:5432 [FQDN="192.168.60.130",Host="1
92.168.60.130",Hostname="192.168.60.130:5432",Port="5432",passwords="postgres",usernames="postgr
es"]
[vnc-default-login] [javascript] [high] 192.168.60.130:5900 [FQDN="192.168.60.130",Host="192.168
.60.130",Hostname="192.168.60.130:5900",Port="5900",passwords="password"]
[CVE-2026-4480:version] [javascript] [critical] 192.168.60.130:445 ["3.0.20"]
[samba-detect] [javascript] [info] 192.168.60.130:445 ["Samba 3.0.20-Debian"]
[vnc-default-login] [javascript] [high] 192.168.60.130:5900 [FQDN="192.168.60.130",Host="192.168
.60.130",Hostname="192.168.60.130:5900",Port="5900",passwords="password123"]
[pgsql-default-db] [javascript] [high] 192.168.60.130:5432 [FQDN="192.168.60.130",Host="192.168.
60.130",Hostname="192.168.60.130:5432",Port="5432",database="postgres",password="postgres",usern
ames="postgres"]
[pgsql-default-db] [javascript] [high] 192.168.60.130:5432 [FQDN="192.168.60.130",Host="192.168.
60.130",Hostname="192.168.60.130:5432",Port="5432",database="template1",password="postgres",user
names="postgres"]
[pgsql-default-db] [javascript] [high] 192.168.60.130:5432 [FQDN="192.168.60.130",Host="192.168.
60.130",Hostname="192.168.60.130:5432",Port="5432",database="template1",password="",usernames="p
ostgres"]
[pgsql-default-db] [javascript] [high] 192.168.60.130:5432 [FQDN="192.168.60.130",Host="192.168.
60.130",Hostname="192.168.60.130:5432",Port="5432",database="postgres",password="",usernames="po
stgres"]
[ntlm-info] [javascript] [info] 192.168.60.130:445 ["NTLM: Samba 3.0.20-Debian"]
[smb-v1-supported] [javascript] [info] 192.168.60.130:445
[smb-version-detect:smb-version] [javascript] [info] 192.168.60.130:445 ["SMB 1.0"]
[pgsql-empty-password] [javascript] [critical] 192.168.60.130:5432
[ajp-protocol-detect] [javascript] [info] 192.168.60.130:8009 ["AJP Detected"]
Activate Windows
Go to Settings to activate Windows.


Home
KALI LINUX
ICDFA Kali Forensics
Metasploitable2-Linux
1 2 3 4
0:41
icdfa@icdfa: ~
File Actions Edit View Help
[ajp-protocol-detect] [javascript] [info] 192.168.60.130:8009 ["AJP Detected"]
[netbios-udp-detect] [javascript] [info] 192.168.60.130:137 ["NetBIOS Name Service Detected"]
[rpc-udp-detect] [javascript] [info] 192.168.60.130:111 ["RPC Portmapper UDP Detected"]
[CVE-2015-1419:version] [tcp] [medium] 192.168.60.130:21 ["2.3.4"]
[CVE-2004-2687] [tcp] [high] 192.168.60.130:3632
[CVE-2021-30047:version] [tcp] [high] 192.168.60.130:21 ["2.3.4"]
[CVE-2011-2523] [tcp] [critical] 192.168.60.130:6200
[ftp-weak-credentials] [tcp] [high] 192.168.60.130:21 [password="password",username="ftp"]
[ftp-detect] [tcp] [info] 192.168.60.130:21
[vsftpd-detect:version] [tcp] [info] 192.168.60.130:21 ["2.3.4"]
[nfs-v3-exposed] [tcp] [info] 192.168.60.130:2049
[openssh-detect] [tcp] [info] 192.168.60.130:22 ["SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1"]
[pgsql-detect] [tcp] [info] 192.168.60.130:5432
[vnc-service-detect] [tcp] [info] 192.168.60.130:5900 ["RFB 003.003"]
[CVE-2020-1938] [tcp] [critical] 192.168.60.130:8009
[http-missing-security-headers:strict-transport-security] [http] [info] http://192.168.60.130
[http-missing-security-headers:permissions-policy] [http] [info] http://192.168.60.130
[http-missing-security-headers:x-permitted-cross-domain-policies] [http] [info] http://192.168.6
0.130
[http-missing-security-headers:cross-origin-embedder-policy] [http] [info] http://192.168.60.130
[http-missing-security-headers:cross-origin-opener-policy] [http] [info] http://192.168.60.130
[http-missing-security-headers:content-security-policy] [http] [info] http://192.168.60.130
[http-missing-security-headers:x-frame-options] [http] [info] http://192.168.60.130
[http-missing-security-headers:x-content-type-options] [http] [info] http://192.168.60.130
[http-missing-security-headers:referrer-policy] [http] [info] http://192.168.60.130
[http-missing-security-headers:cross-origin-resource-policy] [http] [info] http://192.168.60.130
[ftp-anonymous-login] [tcp] [medium] 192.168.60.130:21
[ftp-weak-credentials] [tcp] [high] 192.168.60.130:21 [password="nas",username="ftp"]
[ftp-weak-credentials] [tcp] [high] 192.168.60.130:21 [password="123456",username="ftp"]
[ftp-weak-credentials] [tcp] [high] 192.168.60.130:21 [password="default",username="ftp"]
[ftp-weak-credentials] [tcp] [high] 192.168.60.130:21 [password="guest",username="ftp"]
Activate Windows
Go to Settings to activate Windows.


Home
KALI LINUX
ICDFA Kali Forensics
Metasploitable2-Linux
icdfa@icdfa: ~
File Actions Edit View Help
[http-missing-security-headers:x-content-type-options] [http] [info] http://192.168.60.130
[http-missing-security-headers:referrer-policy] [http] [info] http://192.168.60.130
[http-missing-security-headers:cross-origin-resource-policy] [http] [info] http://192.168.60.130
[ftp-anonymous-login] [tcp] [medium] 192.168.60.130:21
[ftp-weak-credentials] [tcp] [high] 192.168.60.130:21 [password="nas",username="ftp"]
[ftp-weak-credentials] [tcp] [high] 192.168.60.130:21 [password="123456",username="ftp"]
[ftp-weak-credentials] [tcp] [high] 192.168.60.130:21 [password="default",username="ftp"]
[ftp-weak-credentials] [tcp] [high] 192.168.60.130:21 [password="guest",username="ftp"]
[ftp-weak-credentials] [tcp] [high] 192.168.60.130:21 [password="toor",username="ftp"]
[ftp-weak-credentials] [tcp] [high] 192.168.60.130:21 [password="pass1",username="ftp"]
[ftp-weak-credentials] [tcp] [high] 192.168.60.130:21 [password="stingray",username="ftp"]
[INF] Skipped 192.168.60.130:5814 from target list as found unresponsive permanently: Get "https://192.168.60.130:5814/autopass": cause="port closed or filtered" address=192.168.60.130:5814 chain="connection refused"
[apache-detect] [http] [info] http://192.168.60.130 ["Apache/2.2.8 (Ubuntu) DAV/2"]
[apache-httpd-eol:version] [http] [info] http://192.168.60.130 ["2.2.8"]
[php-eol:version] [http] [info] http://192.168.60.130 ["5.2.4"]
[INF] Skipped 192.168.60.130:4040 from target list as found unresponsive permanently: cause="port closed or filtered" address=192.168.60.130:4040 chain="connection refused; got err while executing https://192.168.60.130:4040/jobs/?\"'><script>alert(document.domain)</script>"
[tech-detect:php] [http] [info] http://192.168.60.130
[INF] Skipped 192.168.60.130:80 from target list as found unresponsive permanently: cause="no address found for host" chain="got err while executing https://www.rdap.net/domain/192.168.60.130"
[INF] Scan completed in 2m. 57 matches found.
[INF] HTTP connections: 12325 total, 2975 new, 9350 reused (75.9%)
┌──(icdfa㉿icdfa)-[~]
└─$ cat nuclei_web_scan.txt
[CVE-2012-1823] [http] [high] http://192.168.60.130/index.php?-d+allow_url_include%3don+-d+auto_prepend_file%3dphp%3a//input
[phpmyadmin-panel] [http] [info] http://192.168.60.130/phpMyAdmin/index.php [paths="/phpMyAdmin/
Activate Windows
Go to Settings to activate Windows.


Home
KALI LINUX
ICDFA Kali Forensics
Metasploitable2-Linux
icdfa@icdfa: ~
File Actions Edit View Help
┌──(icdfa㉿icdfa)-[~]
└─$ cat nuclei_web_scan.txt
[CVE-2012-1823] [http] [high] http://192.168.60.130/index.php?-d+allow_url_include%3don+-d+auto_prepend_file%3dphp%3a//input
[phpmyadmin-panel] [http] [info] http://192.168.60.130/phpMyAdmin/index.php [paths="/phpMyAdmin/index.php"]
[phpinfo-files] [http] [low] http://192.168.60.130/phpinfo.php [paths="/phpinfo.php"]
[http-trace:trace-request] [http] [info] http://192.168.60.130
[php-detect] [http] [info] http://192.168.60.130 ["5.2.4"]
[waf-detect:apachegeneric] [http] [info] http://192.168.60.130
[CVE-2026-109618:version-eol-branch] [http] [critical] http://192.168.60.130 ["5.2.4-2ubuntu5.10"]
[postgres-default-logins] [javascript] [high] 192.168.60.130:5432 [FQDN="192.168.60.130",Host="192.168.60.130",Hostname="192.168.60.130:5432",Port="5432",passwords="postgres",usernames="postgres"]
[vnc-default-login] [javascript] [high] 192.168.60.130:5900 [FQDN="192.168.60.130",Host="192.168.60.130",Hostname="192.168.60.130:5900",Port="5900",passwords="password"]
[CVE-2026-4480:version] [javascript] [critical] 192.168.60.130:445 ["3.0.20"]
[samba-detect] [javascript] [info] 192.168.60.130:445 ["Samba 3.0.20-Debian"]
[vnc-default-login] [javascript] [high] 192.168.60.130:5900 [FQDN="192.168.60.130",Host="192.168.60.130",Hostname="192.168.60.130:5900",Port="5900",passwords="password123"]
[pgsql-default-db] [javascript] [high] 192.168.60.130:5432 [FQDN="192.168.60.130",Host="192.168.60.130",Hostname="192.168.60.130:5432",Port="5432",database="postgres",password="postgres",usernames="postgres"]
[pgsql-default-db] [javascript] [high] 192.168.60.130:5432 [FQDN="192.168.60.130",Host="192.168.60.130",Hostname="192.168.60.130:5432",Port="5432",database="template1",password="postgres",usernames="postgres"]
[pgsql-default-db] [javascript] [high] 192.168.60.130:5432 [FQDN="192.168.60.130",Host="192.168.60.130",Hostname="192.168.60.130:5432",Port="5432",database="template1",password="",usernames="postgres"]
Activate Windows
Go to Settings to activate Windows.
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.



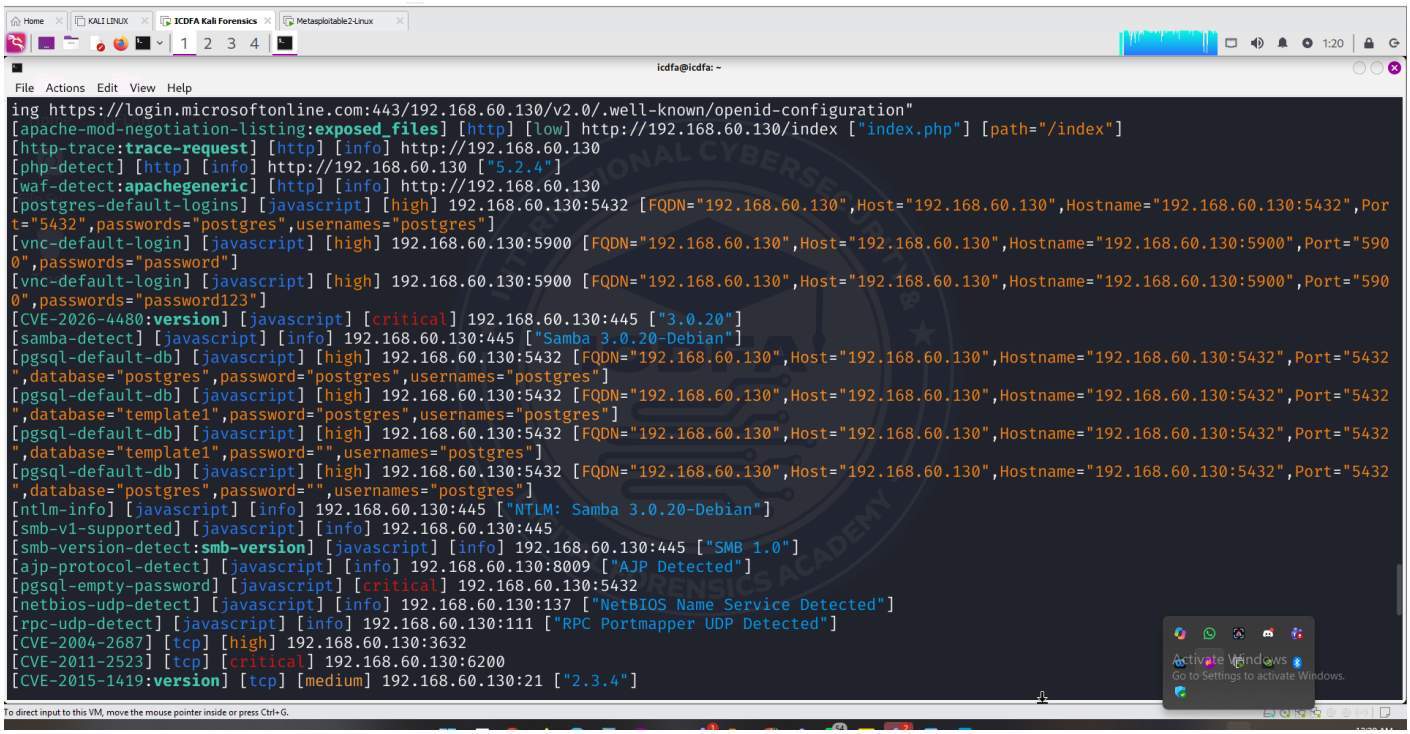


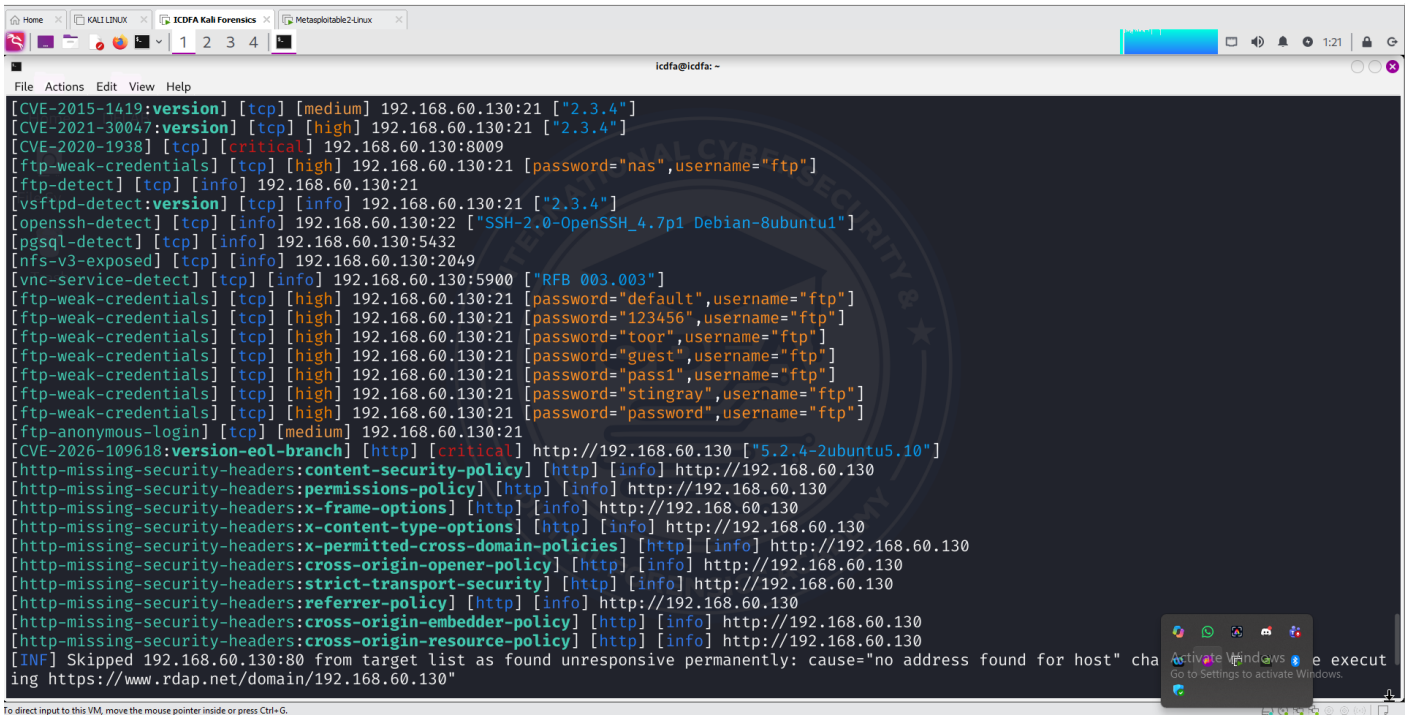
For all services

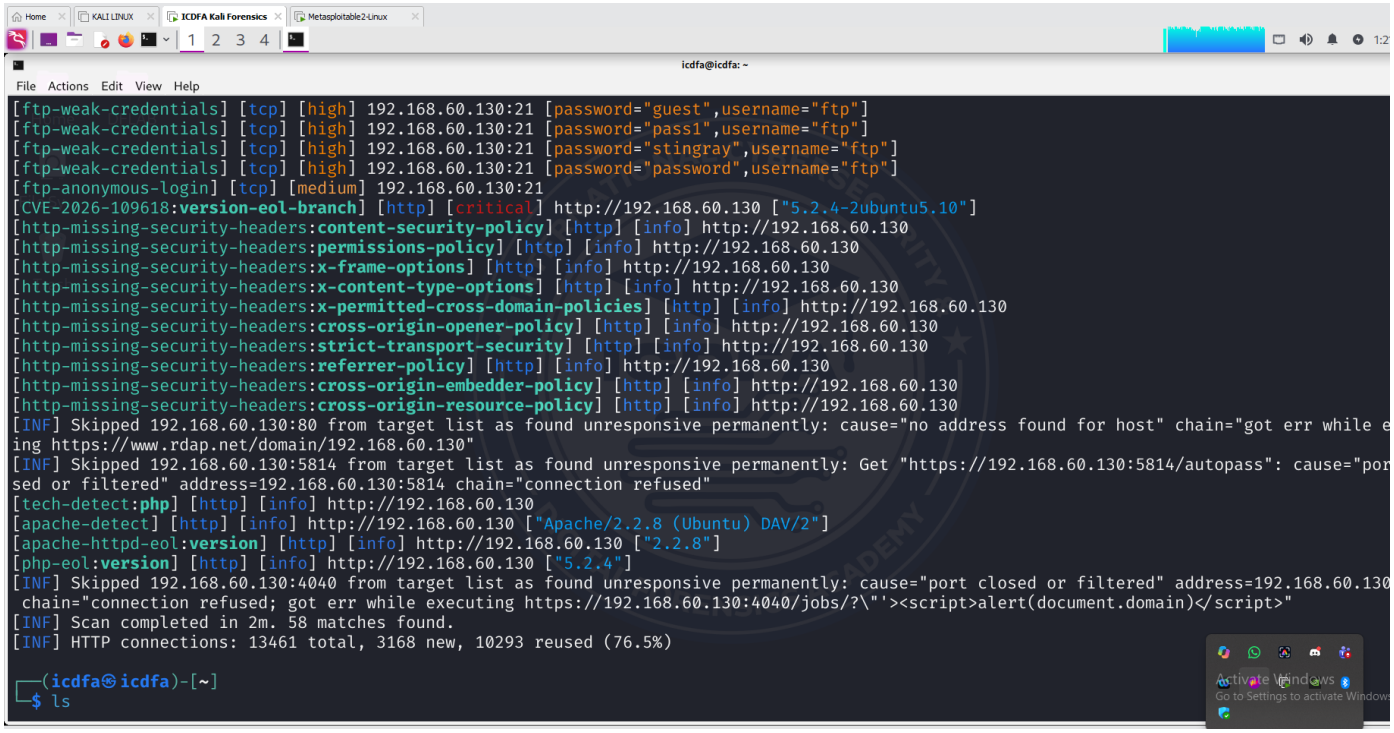
Command: nuclei -target <TARGET_IP> -o nuclei_full_scan.txt

- **Review:** Nuclei output often includes CVE references and severity scores—crucial evidence for risk assessment.


ICDFA Kali Forensics - VMware Workstation
File Edit View VM Tabs Help
Home
KALI LINUX
ICDFA Kali Forensics
Metasploitable2-Linux
1 2 3 4
1:18
icdfa@icdfa: ~
File Actions Edit View Help
[tech-detect:php] [http] [info] http://192.168.60.130
(icdfa㉿icdfa)-[~]
$ nuclei -target 192.168.60.130 -o nuclei_full_scan.txt
v3.11.1
projectdiscovery.io
[INF] Current nuclei version: v3.11.1 (outdated)
[INF] Current nuclei-templates version: v10.5.1 (latest)
[INF] New templates added in latest release: 68
[INF] Templates loaded for current scan: 11212
[INF] Executing 11212 signed templates from projectdiscovery/nuclei-templates
[INF] Targets loaded for current scan: 1
[INF] Running httpx on input host
[INF] Found 1 URL from httpx
[INF] Templates clustered: 2728 (Reduced 2593 Requests)
[CVE-2012-1823] [http] [high] http://192.168.60.130/index.php?-d+allow_url_include%3don+-d+auto_prepend_file%3dphp%3a//input
[INF] Skipped 192.168.60.130:80 from target list as found unresponsive permanently: cause="no address found for host" chain="got err while execut
ing https://checkip.amazonaws.com"
[phpmyadmin-panel] [http] [info] http://192.168.60.130/phpMyAdmin/index.php [paths="/phpMyAdmin/index.php"]
[phpinfo-files] [http] [low] http://192.168.60.130/phpinfo.php [paths="/phpinfo.php"]
[INF] Skipped 192.168.60.130:80 from target list as found unresponsive permanently: cause="no address found for host" cha
ing https://login.microsoftonline.com:443/192.168.60.130/v2.0/.well-known/openid-configuration"
[apache-mod-negotiation-listing:exposed_files] [http] [low] http://192.168.60.130/index ["index.php"] [path="/index"]
[http-trace:trace-request] [http] [info] http://192.168.60.130
Activate Windows
Go to Settings to activate Windows.


Home
KALI LINUX
ICDFA Kali Forensics
Metasploitable2-Linux
1 2 3 4
1:20
icdfa@icdfa: ~
File Actions Edit View Help
ing https://login.microsoftonline.com:443/192.168.60.130/v2.0/.well-known/openid-configuration"
[apache-mod-negotiation-listing:exposed_files] [http] [low] http://192.168.60.130/index ["index.php"] [path="/index"]
[http-trace:trace-request] [http] [info] http://192.168.60.130
[php-detect] [http] [info] http://192.168.60.130 ["5.2.4"]
[waf-detect:apachegeneric] [http] [info] http://192.168.60.130
[postgres-default-logins] [javascript] [high] 192.168.60.130:5432 [FQDN="192.168.60.130",Host="192.168.60.130",Hostname="192.168.60.130:5432",Port="5432",passwords="postgres",usernames="postgres"]
[vnc-default-login] [javascript] [high] 192.168.60.130:5900 [FQDN="192.168.60.130",Host="192.168.60.130",Hostname="192.168.60.130:5900",Port="5900",passwords="password"]
[vnc-default-login] [javascript] [high] 192.168.60.130:5900 [FQDN="192.168.60.130",Host="192.168.60.130",Hostname="192.168.60.130:5900",Port="5900",passwords="password123"]
[CVE-2026-4480:version] [javascript] [critical] 192.168.60.130:445 ["3.0.20"]
[samba-detect] [javascript] [info] 192.168.60.130:445 ["Samba 3.0.20-Debian"]
[pgsql-default-db] [javascript] [high] 192.168.60.130:5432 [FQDN="192.168.60.130",Host="192.168.60.130",Hostname="192.168.60.130:5432",Port="5432",database="postgres",password="postgres",usernames="postgres"]
[pgsql-default-db] [javascript] [high] 192.168.60.130:5432 [FQDN="192.168.60.130",Host="192.168.60.130",Hostname="192.168.60.130:5432",Port="5432",database="template1",password="postgres",usernames="postgres"]
[pgsql-default-db] [javascript] [high] 192.168.60.130:5432 [FQDN="192.168.60.130",Host="192.168.60.130",Hostname="192.168.60.130:5432",Port="5432",database="template1",password="",usernames="postgres"]
[pgsql-default-db] [javascript] [high] 192.168.60.130:5432 [FQDN="192.168.60.130",Host="192.168.60.130",Hostname="192.168.60.130:5432",Port="5432",database="postgres",password="",usernames="postgres"]
[ntlm-info] [javascript] [info] 192.168.60.130:445 ["NTLM: Samba 3.0.20-Debian"]
[smb-v1-supported] [javascript] [info] 192.168.60.130:445
[smb-version-detect:smb-version] [javascript] [info] 192.168.60.130:445 ["SMB 1.0"]
[ajp-protocol-detect] [javascript] [info] 192.168.60.130:8009 ["AJP Detected"]
[pgsql-empty-password] [javascript] [critical] 192.168.60.130:5432
[netbios-udp-detect] [javascript] [info] 192.168.60.130:137 ["NetBIOS Name Service Detected"]
[rpc-udp-detect] [javascript] [info] 192.168.60.130:111 ["RPC Portmapper UDP Detected"]
[CVE-2004-2687] [tcp] [high] 192.168.60.130:3632
[CVE-2011-2523] [tcp] [critical] 192.168.60.130:6200
[CVE-2015-1419:version] [tcp] [medium] 192.168.60.130:21 ["2.3.4"]
Activate Windows
Go to Settings to activate Windows.
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.





The full scan matches 58, against 57 from the web scan as the two overlap almost completely. The only new item is a low-severity apache-mod-negotiation-listing. From this, there are 3 details worth noting as follows:

- ✓ Every FTP password "worked." - Eight different passwords matched for user ftp, which means the server accepts any password for that account. It's effectively the anonymous account, and the finding is "unauthenticated FTP access", not "eight weak passwords."
- ✓ VNC accepted both password and password123 - VNC's older authentication only checks the first eight characters, so both match the same password. That's a weakness in itself.
- ✓ PostgreSQL accepted postgres and a blank password. That points to no real authentication on the database.

Phase 3: Analysis and Reporting (The Core GRC Task)

Step 6: Triage and Risk Assessment

Below is the Risk Assessment table summarizing key findings. There are 11 High, 3 Mediu, AND 1 Low Inherent risks. Items 8 and 11 are from version matching. Findings marked *"confirmed"* came from the tests that exercised the service and the *"version match"* findings are inferred from version numbers.

S/No	Finding	Affected Service	CVE/Reference	Inherent Risk (L/M/H)	Compliance Violation	Business Impact
1	vsFTPd 2.3.4 backdoor (confirmed: shell opened on port 6200)	FTP 21	CVE-2011-2523	H	CIS 7.4; NIST CSF PR.IP-12	Full system compromise
2	Unauthenticated FTP access (anonymous login, any password accepted)	FTP 21	Nuclei: ftp-anonymous-login, ftp-weak-credentials	H	CIS 5.2, 6.1; NIST CSF PR.AC-1	Unauthorized file access and upload
3	Database with empty or default password	PostgreSQL 5432	Nuclei: pgsql-empty-password	H	CIS 4.7, 5.2; NIST CSF PR.AC-1	Theft or tampering of all database data
4	Default or weak VNC password	VNC 5900	Nuclei: vnc-default-login	H	CIS 4.7, 5.2; NIST CSF PR.AC-1	Remote desktop takeover

5	distccd remote command execution	distcc 3632	CVE-2004-2687	H	CIS 4.8, 7.4; NIST CSF PR.PT-3	Remote code execution
6	Tomcat AJP "Ghostcat"	AJP 8009	CVE-2020-1938	H	CIS 7.4; PCI DSS 6.3	Read server files, possible code execution
7	PHP-CGI argument injection	HTTP 80	CVE-2012-1823	H	OWASP A06; PCI DSS 6.3	Web server takeover
8	End-of-life PHP 5.2.4, no vendor fix available	HTTP 80	CVE-2026-109618 (version match)	H	CIS 2.2, 7.4; PCI DSS 6.3.3	Unauthenticated code execution
9	Cleartext Telnet and r-services	23, 512 to 514	N/A (Nmap)	H	NIST CSF PR.DS-2; CIS 3.10, 4.8	Credential sniffing, espionage
10	Unauthenticated root shell	1524	N/A (Nmap)	H	NIST CSF PR.PT-3; CIS 4.8	Instant root access
11	Legacy Samba 3.0.20, SMBv1, signing disabled	SMB 139/445	CVE-2007-2447 (known for this version, not tested by Nuclei); CVE-2026-4480 (version match,	H	CIS 4.8, 7.4	Remote compromise, relay attacks
12	Exposed NFS share service	NFS 2049	Nuclei: nfs-v3-exposed	M	CIS 3.3; NIST CSF PR.AC-4	Data Leakage
13	SSLv2 and expired certificate (valid until 2010)	SMTP 25	N/A (Nmap	M	NIST CSF PR.DS-2; CIS 3.10	Mail Interception
14	Unsupported software (Apache 2.2.8, OpenSSH 4.7, BIND 9.4.2, MySQL 5.0, Tomcat 5.5)	Multiple	Nikto and Nuclei: apache-httpd-eol	M	CIS 2.2, 7.3, 7.4; PCI DSS 6.3.3	Growing pile of unpatched flaws
15	phpMyAdmin exposed, phpinfo.php, TRACE, directory listing, missing security headers	HTTP 80	OWASP A05; PCI DSS 6.4	L	CIS 4.1, 16.x; NIST CSF PR.IP-1	Information disclosure that aids attackers

Inherent Risk Criteria:

- ✓ **High (H):** Easy to exploit, leads to full system compromise.
- ✓ **Medium (M):** Requires some skill, leads to data leakage.
- ✓ **Low (L):** Information disclosure, low impact.

Step 7: The Executive Summary

To: IT Management
From: Adeshola Oluwole – Internal Auditor
Date: October 25, 2026
Subject: High-Risk Security Findings on the Development Server 'Metasploitable'

1. Executive Summary

The vulnerability assessment of the internal development server identified 15 security weaknesses, including 11 rated as high risk. Some of these vulnerabilities can be exploited without authentication or advanced technical skills. During testing, it was also confirmed that one vulnerability could be used to gain a remote command shell on the server.

The server has around 30 network services running, many of which are unnecessary. It also uses outdated software, including components that no longer receive security updates. These weaknesses increase the chances of unauthorised access, data exposure and system compromise. The findings indicate that the server does not meet several security requirements aligned with the CIS Controls and NIST Cybersecurity Framework and as a result of this, immediate action is needed to reduce the risk to the organisation.

2. Key Findings and Risks

- **Critical Risk – Remote System Compromise:** The FTP service contains a known backdoor vulnerability (CVE-2011-2523) that can allow an attacker to gain control of the server without logging in. This was confirmed during testing. Other services, including a build tool and a web component, also have vulnerabilities that could allow remote code execution. These findings highlight gaps in patching and vulnerability management under CIS Control 7.
- **Critical Risk – Unsupported Software:** The server runs an outdated version of PHP (5.2.4) that is no longer supported. The reported vulnerability, CVE-2026-109618, cannot be addressed through a vendor patch for this version. The affected software therefore needs to be replaced with a supported version to reduce the risk of exploitation.

- **High Risk – Weak Authentication:** The database, remote desktop and file transfer services have weak authentication controls, including blank, default or easily guessed passwords. The file transfer service also accepts any password. These weaknesses could allow unauthorised users to access the server and its stored data. This conflicts with CIS Controls 4.7 and 5.2 and NIST CSF PR.AC-1.
- **High Risk – Unencrypted Communications:** Services such as Telnet and FTP transmit login credentials in plain text. Anyone able to monitor the relevant network traffic could capture usernames and passwords, potentially using them to access other systems. This does not meet the security objective of protecting data in transit under NIST CSF PR.DS-2.
- **Medium and Low Risks – Unnecessary Exposure:** Unneeded file-sharing services, an exposed phpMyAdmin interface and missing web security protections increase the server's attack surface. These weaknesses may also reveal useful technical information to an attacker, making further attacks easier.

3. Recommended Actions

- **Isolate the Server:** Immediately restrict the server's network access until the critical vulnerabilities have been addressed. This will help prevent unauthorised access while remediation is underway.
- **Fix Critical Vulnerabilities:** Replace unsupported software, apply available security patches and prioritise the vulnerable FTP service and other components that allow remote code execution.
- **Strengthen Security Controls:** Disable unnecessary services, including Telnet and Rlogin, enforce strong and unique passwords, and use encrypted protocols for remote access and file transfers.
- **Improve Deployment and Monitoring:** Review the process for deploying development servers to ensure that approved security baselines are followed. Conduct regular vulnerability scans and verify that identified issues are resolved before systems are approved for use.

Conclusion: The assessment shows that the Metasploitable server presents a significant security risk, particularly because of its remotely exploitable vulnerabilities, weak authentication and unsupported software. IT Management should prioritise isolating the server and addressing the critical findings before allowing it to return to normal network operations.